

ЗАТВЕРДЖЕНО

Наказом Державна судова адміністрація України
від ____ 2026 р. № ____
(в редакції наказу Державна судова адміністрація України
від ____ 2026 р. № ____)

Єдина судова інформаційно-комунікаційна система (ЄСІКС)
«Органи Суддівського Врядування»

ЦІЛЬОВИЙ ПРОФІЛЬ БЕЗПЕКИ

UA.47850061.C3I.ДП-82

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
1. УПРАВЛІННЯ ДОСТУПОМ (АС)				
1	ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ ДОСТУПОМ (АС-1)	а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]: 1. 2. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики контролю доступу, яка: (а) містить мету, сферу застосування, ролі, відповідальність, зобов’язання керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliances); (b) відповідає чинному законодавству, нормативним документам, директивам, нормам, політикам, стандартам і керівним документам. Процедури, що сприяють реалізації політики управління доступом і відповідних заходів управління доступом. b. Призначити на посаду [Призначення: визначену організацією посадову особу] для управління, документування і розповсюдження політики та процедур контролю доступом. с. Переглянути та оновити: 1. поточну політику управління доступом [Призначення: з визначеною організацією частотою] та [Призначення: події, визначені організацією]; 2. поточні процедури управління доступом [Призначення: з визначеною організацією частотою] та [Завдання: події, визначені організацією].	АС-1	За політику та процедури управління доступом в системі ЄСІКС відповідає підсистема IAM/PKI (Identity and Access Management / Public Key Infrastructure), яка керує обліковими записами, ролями та доступом користувачів згідно з вимогами та політиками ЄСІКС. Параметр: Визначено персонал або ролі, на які поширюється політика контролю доступу Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури контролю доступу Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами контролю доступу Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика контролю доступу Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено події, які вимагають перегляду та оновлення поточної політики контролю доступу Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури контролю доступу Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
2	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)	a. Визначити та задокументувати типи облікових записів системи, дозволених для використання в ІС для підтримки цілей, завдань, функцій і процесів організації. b. Призначити менеджерів облікових записів для управління системними обліковими записами. c. Створити умови для групового та рольового членства. d. Визначити авторизованих користувачів інформаційної системи, членство в групі та ролі, а також дозволи доступу (наприклад, привілеї) та інші атрибути (за потреби) для кожного облікового запису. e. Вимагати схвалення [Призначення: визначеною організацією відповідальною особою або роллю] запитів на створення облікових записів системи. f. Створювати, активувати, змінювати, деактивувати та видаляти системні облікові записи відповідно до [Призначення: визначених організацією політики, процедур та умов]. g. Впровадити моніторинг використання облікових записів системи. h. Повідомляти адміністраторів облікових записів у межах [Призначення: визначеного організацією часового періоду для кожної ситуації]: 1. коли облікові записи більше не потрібні; 2. коли користувачі звільнені чи переведені; 3. коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань. i. Авторизувати доступ до системи на основі: 1. Дійсної авторизації доступу. 2. Передбачуваного використання системи. 3. Інших атрибутів, що вимагаються організацією. j. Проводити перегляд облікових записів на відповідність вимогам управління обліковими записами з [Призначення: визначеною організацією частотою]. k. Впровадити процес повторного випуску облікових даних спільного/групового облікового запису (якщо він буде розгорнутий), коли особи виходять з групи. l. Узгодити процеси управління обліковими записами з процесами звільнення та перевodu (передачі повноважень) персоналу.	АС-2	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистему IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: account_management Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
3	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ (АС-2(3))		АС-2(3)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Облікові записи деактивуються протягом часового періоду, коли облікові записи більше не пов'язані з користувачем або фізичною особою Тип: list Значення: admin, security_officer Параметр: Облікові записи відключено протягом часового періоду, коли облікові записи порушують політику організації; облікові записи деактивуються протягом , якщо вони були неактивними протягом Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Визначено період часу, протягом якого необхідно деактивувати облікові записи Тип: integer Значення: 30 Параметр: Визначено період часу неактивності, після закінчення якого облікові записи будуть деактивовані; АС-02(03)(а) облікові записи деактивуються протягом часового періоду, коли термін дії облікових записів минув Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
4	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ВИХІД ІЗ СИСТЕМИ ЗА ВІДСУТНОСТІ АКТИВНОСТІ (АС-2(5))		АС-2(5)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Користувачі повинні виходити з системи, коли період очікуваної бездіяльності або опис часу, коли потрібно вийти з системи Тип: integer Значення: 30 Параметр: Визначено часовий період очікуваної бездіяльності або опис, коли потрібно вийти з системи Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
5	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ ОСІБ З ВИСОКИМ РІВНЕМ РИЗИКУ (АС-2(13))		АС-2(13)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Облікові записи користувачів деактивуються протягом періоду часу з моменту виявлення значних ризиків Тип: integer Значення: 30 Параметр: Визначено період часу, протягом якого необхідно деактивувати облікові записи фізичних осіб, які становлять значний ризик Тип: integer Значення: 30
6	ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)	Застосовувати затверджені повноваження для логічного доступу до інформації та ресурсів системи відповідно до чинної політики (правил) управління доступом.	АС-3	Усі запити до ресурсів системи примусово проходять через Policy Decision Point (PDP) модуля 'abac'. Прямий доступ до даних в обхід механізмів авторизації заборонено архітектурно. Параметр: access_enforcement Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
7	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)	Застосувати затверджені повноваження для управління потоком інформації всередині системи та між пов'язаними системами на основі [Призначення: визначеними організацією політиками управління інформаційним потоком].	АС-4	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Затверджені повноваження застосовуються для контролю потоку інформації всередині системи та між підключеними системами на основі політики управління інформаційними потоками Тип: list Значення: default _ deny_rule, abac_rule_1 Параметр: Визначено політики управління інформаційними потоками всередині системи та між підключеними системами Тип: list Значення: default _ deny_rule, abac_rule_1
8	РОЗМЕЖУВАННЯ ОБОВ'ЯЗКІВ (АС-5)	а. Розмежувати і документувати [Призначення: визначені організацією обов'язки окремих осіб]. б. Установити правила авторизації доступу для підтримки розмежування обов'язків.	АС-5	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
9	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (АС-6)	Впровадити принцип мінімізації повноважень, який дозволяє користувачам (або процесам, що діють від імені користувачів) здійснювати лише такі авторизовані звернення, які необхідні для виконання визначених завдань відповідно до цілей (призначення, місії) організації та функцій.	АС-6	Профілі безпеки і ролі конфігуруються таким чином, що користувачам надаються лише ті привілеї, які необхідні для виконання їхніх посадових обов'язків. Механізм дозволів 'abac' працює за принципом 'Default-Deny'. Параметр: least_privilege Тип: boolean Значення: true
10	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - АВТОРИЗОВАНИЙ ДОСТУП ДО ФУНКЦІЙ БЕЗПЕКИ (АС-6(1))		АС-6(1)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та ABAC (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Визначені особи або ролі з авторизованим доступом до функцій безпеки та інформації, що має відношення до безпеки Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
11	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (АС-6(2))		АС-6(2)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Користувачі облікових записів (або ролей) системи з доступом до функцій безпеки або інформації, що стосується безпеки, повинні використовувати непривілейовані облікові записи або ролі під час доступу до незахищених функцій Тип: list Значення: admin, security_officer
12	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ПРИВІЛЕЙОВАНІ ОБЛІКОВІ ЗАПИСИ (АС-6(5))		АС-6(5)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Привілейовані облікові записи в системі обмежено персонал або ролі Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, яким мають бути обмежені привілейовані облікові записи в системі Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
13	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ПЕРЕГЛЯД ПОВНОВАЖЕНЬ КОРИСТУВАЧА (АС-6(7))		АС-6(7)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Повноваження, призначені ролям і класам, переглядаються з частотою для перевірки необхідності таких повноважень Тип: integer Значення: 30 Параметр: Визначено частоту перегляду повноважень, призначених ролям або класам користувачів Тип: integer Значення: 30 Параметр: Визначено ролі або класи користувачів, яким призначено повноваження Тип: list Значення: admin, security_officer
14	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-6(9))		АС-6(9)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
15	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (АС-6(10))		АС-6(10)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
16	НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)	а. Встановити обмеження на [Призначення: визначену організацією кількість] послідовних неуспішних спроб входу користувача в систему впродовж [Призначення: визначеного організацією часового періоду]. б. Автоматично виконати [Вибір (один або декілька): блокування облікового запису/вузла на [Призначення: визначений організацією часовий період]; блокування облікового запису/вузла, доки він не буде розблокований адміністратором; затримання наступної команди входу в систему за [Надання: визначеним організацією алгоритмом затримки]; виконати [Призначення: визначені організацією дії]], коли перевищено максимальну кількість невдалих спроб входу в систему.	АС-7	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Застосовано обмеження на кількість послідовних неуспішних спроб входу користувача протягом періоду часу Тип: integer Значення: 30 Параметр: Визначається кількість послідовних неуспішних спроб входу користувача, дозволених протягом певного періоду часу Тип: integer Значення: 30 Параметр: Визначено період часу, яким обмежується кількість послідовних неуспішних спроб входу користувача Тип: integer Значення: 30 Параметр: Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {зблокувати обліковий запис або вузол на період часу; заблокувати обліковий запис або вузол до зняття адміністратором; затримати наступний запит на вхід за алгоритмом затримки; повідомити системного адміністратора; виконати іншу дію} Тип: string Значення: AES-256-GCM

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Період часу, на який буде заблоковано обліковий запис або вузол (якщо вибрано) Тип: integer Значення: 30 Параметр: Визначено алгоритм затримки наступного запиту на вхід (якщо вибрано) Тип: string Значення: AES-256-GCM Параметр: Інша дія, яка буде виконана після перевищення максимальної кількості невдалих спроб (якщо вибрано) Тип: integer Значення: 3
17	НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ - ОЧИЩЕННЯ АБО СТИРАННЯ МОБІЛЬНОГО ПРИСТРОЮ (АС-7(2))		АС-7(2)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та ABAC (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Інформація очищується або стирається з мобільних пристроїв на основі вимог або методів очищення або стирання після <АС-07(02)_ODP[03 кількість> послідовних, невдалих спроб входу на пристрій Тип: integer Значення: 3 Параметр: Визначається кількість послідовних невдалих спроб входу в систему до того, як інформація буде очищена або стерта з мобільних пристроїв Тип: integer Значення: 3

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
18	ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)	а. б. Демонструвати користувачам [Призначення: визначене організацією сповіщення або банер про використання системи] перед тим, як надавати доступ до системи, що забезпечує безпеку та приватність відповідно до чинних законів, нормативних документів, наказів, директив, політик, правил, стандартів і керівних принципів, які зазначають, що: 1. користувачі здійснюють доступ до урядової системи; 2. використання системи може контролюватися, реєструватися та підлягати аудиту; 3. несанкціоноване використання системи забороняється та приводить до кримінальної та цивільної відповідальності; 4. використання системи означає згоду на моніторинг і запис дій користувача. Зберігати сповіщення або банер на екрані, доки користувачі не визнають умови використання та не приймуть явних дій для входу в систему або подальшого доступу до системи. с. Для загальнодоступних систем: 1. демонструвати інформацію про умови використання системи [Призначення: визначені організацією умови], перш ніж надавати подальший доступ до загальнодоступної системи; 2. демонструвати посилання, якщо такі є, на моніторинг, запис або аудит, які узгоджуються з акомодацією приватності для таких систем, які зазвичай забороняють такі дії; 3. мати опис авторизованого використання системи.	АС-8	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Визначається сповіщення або банер про використання системи, який система буде показувати користувачам перед наданням доступу до системи; визначено умови використання системи, які система відображатиме перед наданням подальшого доступу; повідомлення про використання системи відображається користувачам перед наданням доступу до системи, яке містить повідомлення про конфіденційність і безпеку, що відповідають чинним законам, нормативним документам, наказам, директивам, політикам, правилам, стандартам і керівним принципам; у повідомленні про використання системи зазначено, що користувачі отримують доступ до урядової системи; у повідомленні про використання системи зазначено, що використання системи може контролюватися, реєструватися та підлягати аудиту; у повідомленні про використання системи зазначено, що несанкціоноване використання системи заборонено і тягне за собою кримінальну та цивільну відповідальність; у повідомленні про використання системи зазначено, що використання системи означає

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
19	БЛОКУВАННЯ ПРИСТРОЮ (АС-11)	а. Заборонити подальший доступ до системи шляхом ініціювання блокування пристрою після [Призначення: визначеного організацією періоду] бездіяльності або після отримання запиту від користувача. б. Зберігати блокування пристрою, поки користувач не відновить доступ, використовуючи встановлені процедури ідентифікації та автентифікації.	АС-11	Сеанс користувача автоматично блокується системою ('sync/n2o' session expiry) після визначеного періоду бездіяльності, вимагаючи повторної автентифікації. Параметр: session_lock_timeout Тип: integer Значення: 900
20	БЛОКУВАННЯ ПРИСТРОЮ - ПРИХОВАНІ ДИСПЛЕЇ (АС-11(1))		АС-11(1)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та ABAC (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.
21	Припинення сеансу (АС-12)	Сеанс користувача має завершуватися автоматично після [Призначення: визначених організацією умов або тригерних подій, що вимагають припинення сеансу].	АС-12	Користувач може ініціювати завершення сеансу (logout). Крім того, система примусово завершує сеанси при досягненні максимального часу життя токена або зміни контексту безпеки. Параметр: session_termination Тип: boolean Значення: true
22	АВТОМАТИЗОВАНЕ МАРКУВАННЯ (АС-15)		АС-15	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та ABAC (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
23	АТРИБУТИ БЕЗПЕКИ ТА ПРИВАТНОСТІ (АС-16)	a. Визначити засоби для асоціювання (пов'язання) [Призначення: визначених організацією типів атрибутів безпеки та приватності], що приймають [Призначення: визначені організацією значення атрибутів безпеки та приватності] з інформацією, яка зберігається, обробляється та/або передається. b. Пов'язані атрибути безпеки та приватності мають створюватися і зберігатися разом з інформацією. c. Встановити дозволені [Призначення: визначені організацією атрибути безпеки] для [Призначення: систем, визначених організацією]. d. Визначити дозволені [Призначення: визначені організацією значення або діапазони] для кожного з встановлених атрибутів безпеки та приватності.	АС-16	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Визначено типи атрибутів безпеки, які мають бути пов'язані зі значеннями атрибутів безпеки для інформації, що зберігається, обробляється та/або передається; визначено значення атрибутів конфіденційності для типів атрибутів конфіденційності; визначено системи, для яких мають бути встановлені дозволені атрибути безпеки; визначено системи, для яких мають бути встановлені дозволені атрибути конфіденційності; визначено атрибути безпеки, визначені як частина АС-16(a), які дозволені для систем; визначено атрибути конфіденційності, визначені як частина АС-16(a), які дозволені для систем; визначено значення атрибутів або діапазони для встановлених атрибутів; визначено частоту, з якою слід переглядати атрибути безпеки на предмет відповідності; визначено частоту, з якою слід переглядати атрибути конфіденційності на предмет відповідності; надано засоби для асоціювання типів атрибутів безпеки зі значеннями атрибутів безпеки для інформації, що зберігається, обробляється та/або передається надано засоби для асоціювання типів атрибутів

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
24	ВІДДАЛЕНИЙ ДОСТУП (АС-17)	а. Встановити та задокументувати обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення кожного типу віддаленого доступу. б. Авторизувати віддалений доступ до системи, перш ніж будуть дозволені такі підключення.	АС-17	Віддалений доступ до системи керується додатковими політиками (наприклад, перевірка IP-адреси, VPN, mTLS), які інтегруються з 'sync/ca' та 'abac' для забезпечення безпеки доступу за межами захищеного периметра. Параметр: remote_access_control Тип: boolean Значення: true
25	ВІДДАЛЕНИЙ ДОСТУП - КЕРОВАНІ ТОЧКИ КОНТРОЛЮ ДОСТУПУ (АС-17(3))		АС-17(3)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та ABAC (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.
26	ВІДДАЛЕНИЙ ДОСТУП - ПРИВІЛЕЙОВАНІ КОМАНДИ ТА ДОСТУП (АС-17(4))		АС-17(4)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та ABAC (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.
27	БЕЗДРОТОВИЙ ДОСТУП (АС-18)	а. Установити обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення бездротового доступу. б. Авторизувати бездротовий доступ до системи, перш ніж будуть дозволені такі підключення.	АС-18	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
28	БЕЗДРОТОВИЙ ДОСТУП - АВТЕНТИФІКАЦІЯ ТА ШИФРУВАННЯ (АС-18(1))		АС-18(1)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Бездротовий доступ до системи захищений за допомогою шифрування Тип: string Значення: AES-256-GCM
29	БЕЗДРОТОВИЙ ДОСТУП - ВІДКЛЮЧЕННЯ БЕЗДРОТОВОЇ МЕРЕЖІ (АС-18(3))		АС-18(3)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.
30	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)	а. Встановити обмеження на використання, вимоги до конфігурації, вимоги до підключення і рекомендації щодо впровадження мобільних пристроїв, контрольованих організацією. б. Авторизувати підключення мобільних пристроїв до систем, які експлуатуються організацією.	АС-19	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
31	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИЙ ПРИСТРОЇВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ (АС-19(1))		АС-19(1)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.
32	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ (АС-19(2))		АС-19(2)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]. АС-19(03) КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ З НЕІДЕН- ТИФІКОВАНИМ ВЛАСНИКОМ [Вилучено: Включено в МР-07] Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
33	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ОБМЕЖЕННЯ ДЛЯ ЗАСЕКРЕЧЕНОЇ ІНФОРМАЦІЇ (АС-19(4))		АС-19(4)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Використання незахищених мобільних пристроїв на об'єктах, що містять системи, які обробляють, зберігають або передають секретну інформацію, заборонено, за винятком випадків, коли на це є спеціальний дозвіл уповноваженої посадової особи; АС-19(04)(b)(01) заборона підключення незахищених мобільних пристроїв до систем з обмеженим доступом застосовується до осіб, яким уповноважена посадова особа дозволила використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(02) дозвіл уповноваженої посадової особи на підключення незахищених мобільних пристроїв до незахищених систем вимагається від осіб, яким дозволено використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(03) заборона використання внутрішніх або зовнішніх модемів чи бездротових

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
34	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ПОВНЕ ШИФРУВАННЯ ПРИСТРОЇВ ТА СХОВИЩ ІНФОРМАЦІЇ (АС-19(5))		АС-19(5)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв.
35	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)	а. [Вибір (один або кілька): Встановіть [Призначення: умови, визначені організацією]; Визначте [Призначення: визначені організацією засоби контролю, які, як стверджується, будуть реалізовані на зовнішніх системах]], узгоджені з довірчими відносинами, встановленими з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи, дозволяючи уповноваженим особам: 1. доступ до системи із зовнішніх систем; 2. обробляти, зберігати або передавати керовану організацією інформацію за допомогою зовнішніх систем; б. Заборонити використання [Призначення: організаційно-визначені типи зовнішніх систем].	АС-20	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити умови та положення; визначити заходи захисту} Тип: list Значення: Параметр: Визначено умови та положення, що відповідають довірчим відносинам, встановленим з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи (якщо вибрано) Тип: list Значення:

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
36	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ - ОБМЕЖЕННЯ НА АВТОРИЗОВАНЕ ВИКОРИСТАННЯ (АС-20(1))		АС-20(1)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після перевірки виконання заходів безпеки та конфіденційності, зазначених у політиці безпеки та конфіденційності організації, а також планах безпеки та конфіденційності (якщо такі застосовуються) Тип: list Значення: admin, security_officer Параметр: Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після збереження погоджених угод про підключення або обробку системи з структурою організації, на якій розміщена зовнішня система Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
37	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ - ПЕРЕНОСНІ ПРИСТРОЇ ЗБЕРІГАННЯ ДАНИХ (АС-20(2))		АС-20(2)	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Використання портативних пристроїв носіїв інформації уповноваженими особами обмежено у зовнішніх системах за допомогою обмеження Тип: list Значення: admin, security_officer Параметр: Визначено обмеження на використання авторизованими особами портативних носіїв інформації у зовнішніх системах Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
38	ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)	a. Призначити осіб, що уповноважені на розміщення інформації в загальнодоступній системі. b. Навчати уповноважених осіб тому, щоб загальнодоступна інформація не містила інформацію з обмеженим доступом. c. Переглядати запропонований зміст інформації до публікації в загальнодоступній системі, щоб гарантувати, що там не міститься інформація з обмеженим доступом. d. Переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом з [Призначення: визначеною організацією частотою]; така інформація має бути видалена в разі її виявлення.	АС-22	Політики управління доступом, привілеями та віддаленим доступом реалізуються централізовано через підсистеми IAM (Identity and Access Management) та АВАС (Attribute-Based Access Control) ЄСІКС з дотриманням принципу найменших привілеїв. Параметр: Визначені особи уповноважені на розміщення інформації в загальнодоступній системі Тип: list Значення: admin, security_officer Параметр: Уповноважені особи проходять навчання, щоб гарантувати, що загальнодоступна інформація не містить інформацію з обмеженим доступом Тип: list Значення: admin, security_officer Параметр: Зміст у загальнодоступній системі перевіряється на наявність інформації з обмеженим доступом з частотою Тип: integer Значення: 30 Параметр: Визначено частоту, з якою слід переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
2. ОБІЗНАНІСТЬ ТА НАВЧАННЯ (АТ)				
39	ПОЛІТИКА ТА ПРОЦЕДУРИ ПІДВИЩЕННЯ ОБІЗНАНОСТІ ТА НАВЧАННЯ (АТ-1)	а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики обізнаності та навчання у сфері забезпечення безпеки та приватності, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам. 2. Процедури, що сприяють реалізації політики підвищення обізнаності та професійної підготовки в галузі безпеки, приватності, а також пов'язаних з ними заходів захисту інформації та персональних даних. b. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами підвищення обізнаності та навчання у сфері забезпечення безпеки та приватності. с. Переглядати та оновлювати: 1. Поточну політику [Призначення: частота, визначена організацією] і наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].	АТ-1	Відповідальність за навчання та обізнаність з питань кібербезпеки несе організація-користувач відповідно до загальних політик ЄСІКС.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
40	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)	Впровадити базові тренінги з підвищення обізнаності у сфері безпеки та приватності для користувачів системи (включно з менеджерами, керівниками компаній і підрядниками): а. Забезпечити навчання грамотності з питань безпеки та конфіденційності для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників): 1. як частину початкового навчання для нових користувачів і [Призначення: частота, визначена організацією] після цього; 2. якщо цього потребують системні зміни або наступні [Призначення: події, визначені організацією]. б. Використовувати наведені нижче методи, щоб підвищити рівень безпеки та конфіденційності користувачів системи [Завдання: визначені організацією методи поінформованості]; с. Оновлювати навчання грамотності та зміст обізнаності [Завдання: частота, визначена організацією] і наступні [Завдання: події, визначені організацією]; д. Включити уроки, отримані з внутрішніх або зовнішніх інцидентів безпеки або порушень, у навчання грамотності та методи підвищення обізнаності.	АТ-2	Програми навчання та інструктажі (див. розділ АТ у digital-profile.pdf). Параметр: security_awareness_training_ref Тип: string Значення: digital-profile.pdf
41	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ		АТ-2(2)	Відповідальність за навчання та обізнаність з питань кібербезпеки несе організація-користувач відповідно до загальних політик ЄСІКС.
42	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ		АТ-2(3)	Відповідальність за навчання та обізнаність з питань кібербезпеки несе організація-користувач відповідно до загальних політик ЄСІКС.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
43	РОЛЬОВЕ НАВЧАННЯ (АТ-3)	а. Забезпечити проведення навчання з питань безпеки та приватності на основі ролей для працівників з ролями та обов'язками: [Призначення: визначені організацією ролі та обов'язки]: - перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків і [Призначення: частота, визначена організацією] після цього; - коли цього потребують системні зміни. б. Оновити навчальний контент на основі ролей [Призначення: частота, визначена організацією] і наступні [Призначення: події, визначені організацією]; с. Включіть у рольове навчання, інформацію, отриману з внутрішніх або зовнішніх інцидентів та порушень безпеки.	АТ-3	Спеціалізоване навчання для адміністраторів (див. розділ АТ у digital-profile.pdf). Параметр: role_based_training_ref Тип: string Значення: digital-profile.pdf

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
3. АУДИТ ТА ПІДЗВІТНІСТЬ (AU)				
44	Політика та процедури аудиту та підзвітності (AU-1)	a. Розробити, задокументувати та поширити [Призначення: серед персоналу або ролей, що їх визначила організація]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика аудиту та підзвітності, яка: (a) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам. 2. Процедури, що сприяють здійсненню політики аудиту та підзвітності, а також пов'язані з ними заходи аудиту та підзвітності. b. Призначити [Призначення: визначену організацією старшу посадову особу] для управління політикою та процедурами аудиту та підзвітності. c. Переглядати та оновлювати поточний аудит та підзвітність: 1. політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. процедури аудиту [Призначення: визначеною організацією частотою] та [Завдання: події, визначені організацією].	AU-1	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців. Параметр: Розроблено та задокументовано політику аудиту та підзвітності Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика аудиту та підзвітності доведена до персонал або ролі Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури аудиту та підзвітності, що сприяють впровадженню політики аудиту та підзвітності, а також відповідні заходи контролю аудиту та підзвітності Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління політикою та процедурами аудиту та підзвітності AU-01(c)[01][01] переглядається та оновлюється поточна політика аудиту та підзвітності з частота; AU-01(c)[01][02] переглядається та оновлюється поточна політика аудиту та підзвітності після подій; AU-01(c)[02][01] переглядається та оновлюється поточні процедури аудиту та підзвітності з частота; AU-01(c)[02][02] переглядається та оновлюється поточні процедури аудиту та підзвітності після

29

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено персонал або ролі, до яких має бути доведена політика аудиту та підзвітності Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури аудиту та підзвітності Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка управлятиме політикою та процедурами аудиту та підзвітності Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика аудиту та підзвітності Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено події, які потребують перегляду та оновлення поточної політики аудиту та підзвітності Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури аудиту та підзвітності Тип: integer Значення: 30 Параметр: Визначено події, які потребують перегляду та оновлення поточної процедури аудиту та підзвітності Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
45	ПОДІЇ АУДИТУ (AU-2)	а. Визначити типи подій, які система може реєструвати для підтримки функції аудиту: [Призначення: типи подій, визначені організацією, які система здатна реєструвати]; б. Координувати функції аудиту безпеки з іншими організаційними підрозділами, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються; с. Визначити, які типи подій підлягають аудиту: [Призначення: визначені організацією події, що підлягають аудиту (підмножина подій, що підлягають аудиту, визначених в AU-2 а.), а також частота (або ситуація, що вимагає) проведення аудиту для кожної ідентифікованої події] д. Обґрунтувати, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та приватністю; е. Перегляньте й оновіть типи подій, вибрані для журналювання [Призначення: частота, визначена організацією].	AU-2	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців. Параметр: Зазначені типи подій реєструються 02_ODP[03] частота або ситуація>; <AU-Тип: string Значення: щорічно Параметр: Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота, у системі Тип: string Значення: щорічно Параметр: Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події Тип: list Значення: login, logout, failed_attempt Параметр: Частота перегляду та оновлення типів подій, обраних для журналювання Тип: string Значення: щорічно
46	ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)	Переконавшись, що записи аудиту містять інформацію, яка встановлює наступне: а. який тип події стався; б. коли відбулася подія; с. де відбулася подія; д. джерело події; е. наслідки події; ф. результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією.	AU-3	Інформація в логах ВРМН (особливо при збереженні об'єктів ВРЕ/ABAC) містить вичерпні метадані: тип події, суб'єкт, цільовий об'єкт, результат операції (Permit/Deny) та позначку часу, що повністю закриває вимоги AU-3. Параметр: audit_content_metadata Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
47	ЗМІСТ ЗАПИСІВ АУДИТУ - ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ (AU-3(1))		AU-3(1)	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців.
48	РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5)	а. Сповіщати [Призначення: визначені організацією персонал або посади] у разі збою обробки даних аудиту в [Призначення: визначений організацією період часу]. б. Виконати наступні додаткові дії: [Призначення: визначені організацією дії, які необхідно зробити].	AU-5	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців. Параметр: Персонал або ролі отримують сповіщення у разі збою процесу обробки даних аудиту періоду часу Тип: list Значення: admin, security_officer Параметр: Додаткові дії виконуються у разі збою процесу обробки даних аудиту Тип: list Значення: login, logout, failed_attempt Параметр: Визначено персонал або ролі, які отримують сповіщення про збої в процесі обробки даних аудиту Тип: list Значення: admin, security_officer Параметр: Визначено період часу, протягом якого персонал або ролі отримують сповіщення про збої в процесі обробки даних аудиту Тип: list Значення: admin, security_officer Параметр: Визначено додаткові дії, яких слід вжити у випадку збою в процесі обробки даних аудиту Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
49	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)	а. Переглядати та аналізувати записи системного аудиту [Призначення: з визначеною організацією частотою] для виявлення [Призначення: визначеної організацією неналежної або незвичайної діяльності]. б. Відправляти звіт про аудит [Призначення: визначеним організацією персоналу або посадам]. с. Налаштувати рівні огляду аудиту, аналізу та звітності в рамках системи, коли змінюється рівень ризику на основі інформації від правоохоронних органів, розвідувальної інформації або від інших достовірних джерел інформації.	AU-6	Аналіз аудиту відбувається за допомогою консольних інструментів платформи (наприклад, 'kvs:hist/1' або інтерфейсів Erlang Shell). Також доступний експорт журналів для SIEM. Параметр: audit_analysis_tools Тип: boolean Значення: true
50	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ - ЗІСТАВЛЯННЯ СХОВИЩ АУДИТУ (AU-6(3))		AU-6(3)	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців.
51	СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7)	Забезпечити та реалізувати можливості скорочення записів перевірок аудитом і звітів, до рівня, який: а. підтримує перевірку, аналіз і звітність аудиту на вимогу та розслідування (постфактум) інцидентів безпеки; б. не змінює оригінальний вміст або час упорядкування записів аудиту.	AU-7	Параметр: Забезпечено можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту Тип: integer Значення: 30 Параметр: Реалізовано можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
52	ПОЗНАЧКА ЧАСУ (AU-8)	а. Використовувати внутрішньосистемний годинник для створення позначок часу для записів аудиту. б. Застосовувати позначки часу, які відповідають [Призначення: деталізація вимірювання часу, визначена організацією] і використовують всесвітній координований час, мають фіксоване зміщення місцевого часу відносно всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу.	AU-8	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців. Параметр: Внутрішній системний годинник використовується для створення позначок часу для записів аудиту Тип: integer Значення: 30 Параметр: Позначки часу застосовуються для записів аудиту, які відповідають деталізація вимірювання часу і які використовують всесвітній координований час, мають фіксоване місцеve зміщення місцевого часу від всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу Тип: integer Значення: 30 Параметр: Визначено деталізацію вимірювання часу для часових позначок записів аудиту Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
53	ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)	а. Захист інформації аудиту та інструментів несанкціонованого доступу, зміни та видалення; б. Сповідання [Призначення: персонал або ролі, визначені організацією] у разі виявлення несанкціонованого доступу, зміни або видалення інформації аудиту.	AU-9	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців. Параметр: Персонал або ролі отримують сповіщення при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, які мають бути сповіщені при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту Тип: list Значення: admin, security_officer
54	ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ - ДОСТУП, ЯКИЙ НАДАЄТЬСЯ ЧЕРЕЗ ЧЛЕНСТВО В ПІДМНОЖИНИ ПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (AU-9(4))		AU-9(4)	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
55	НЕСПРОСТОВНІСТЬ (AU-10)	Надавайте неспростовні докази того, що особа (або процес, який діє від імені особи) виконала [Призначення: дії, визначені організацією, на які поширюється принцип неспростовності].	AU-10	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців. Параметр: Надаються неспростовні докази того, що особа (або процес, що діє від імені особи) виконала дії Тип: list Значення: admin, security_officer Параметр: Визначено дії, на які поширюється принцип неспростовності Тип: list Значення: login, logout, failed_attempt
56	НЕСПРОСТОВНІСТЬ - ЦИФРОВІ ПІДПИСИ (AU-10(5))		AU-10(5)	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
57	ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11)	Зберігати записи аудиту впродовж [Призначення: визначеного організацією періоду часу, відповідно політиці зберігання записів], щоб забезпечити підтримку розслідувань (постфактум) інцидентів безпеки та приватності, а також для задоволення вимог нормативних і документів організації щодо збереження даних аудиту.	AU-11	Підсистема логування та аудиту автоматично фіксує всі події доступу (автентифікації/авторизації) та зміни даних. Журнали аудиту зберігаються в імутабельному сховищі не менше 3 місяців. Параметр: Записи аудиту зберігаються впродовж період часу, щоб забезпечити підтримку розслідування (постфактум) інцидентів безпеки та конфіденційності, а також відповідати нормативним та вимогам організації щодо збереження даних аудиту Тип: integer Значення: 30 Параметр: Визначено період часу для зберігання записів аудиту, який узгоджується з політикою зберігання записів Тип: list Значення: default _deny_rule, abac_rule_1
58	ГЕНЕРАЦІЯ ДАНИХ АУДИТУ (AU-12)	а. Забезпечити генерацію даних аудиту для типів подій, що перевіряються в AU-2a в [Призначення: визначених організацією компонентах системи]. б. Дозволити [Призначення: визначеному організацією персоналу або посадам] вибирати, які типи подій, що перевіряються, повинні перевірятися окремими компонентами системи; с. Генерувати записи аудиту для типів подій, визначених в AU-2с. з вмістом згідно з AU-3.	AU-12	KVS забезпечує генерацію записів аудиту для всіх операцій створення, оновлення (через створення нової ревізії) та видалення, гарантуючи фіксацію критичних подій безпеки. Параметр: audit _generation Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
4. ОЦІНЮВАННЯ, АВТОРИЗАЦІЯ ТА МОНІТОРИНГ (СА)				
59	ПОЛІТИКА І ПРОЦЕДУРИ ОЦІНЮВАННЯ, АКРЕДИТАЦІЯ ТА МОНІТОРИНГ БЕЗПЕКИ (СА-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика оцінювання, авторизації та моніторингу, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, наказам, положенням, політиці, стандартам і керівним принципам. 2. Процедури, що сприяють реалізації політики оцінювання, авторизації та моніторингу безпеки та приватності, а також пов'язаних з ними заходів оцінювання, авторизації та моніторингу безпеки та приватності. б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; с. Переглядати та оновлювати поточне оцінювання, авторизацію та моніторинг: 1. Політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].	СА-1	Моніторинг та авторизація компонентів ЄСІКС здійснюється на рівні інфраструктури безпеки, з регулярною перевіркою відповідності стандартам (OWASP Top 10, ДСТУ). Параметр: Розроблено та задокументовано політику оцінювання, авторизації та моніторингу Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика оцінювання, авторизації та моніторингу поширюється серед персоналу або ролей Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури оцінювання, авторизації та моніторингу, що сприяють впровадженню політики оцінювання, авторизації та моніторингу, а також пов'язані з ними засоби контролю оцінювання, авторизації та моніторингу Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; СА-01(с)[01][01] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу з частотою; СА-01(с)[01][02] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу з частотою;

38

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено персонал або ролі, серед яких має бути поширена політика оцінювання, авторизації та моніторингу Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, серед яких мають бути поширені процедури оцінювання, авторизації та моніторингу Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка управлятиме розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика оцінювання, авторизації та моніторингу Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено події, які потребують перегляду та оновлення поточної політики оцінки, авторизації та моніторингу Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядається та оновлюється поточні процедури оцінювання, авторизації та моніторингу Тип: integer Значення: 30 Параметр: Визначено події, які потребують перегляду та оновлення поточні процедури оцінки, авторизації та моніторингу Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
60	ОЦІНЮВАННЯ (CA-2)	a. Виберіть відповідного оцінювача або команду з оцінки для типу оцінювання, яке буде проводитися; b. Розробіть план контрольної оцінки, який описує обсяг оцінки, в тому числі: 1. заходи захисту та посилені заходи, що підлягають оцінюванню; 2. процедури оцінювання, ефективності заходів; які використовуватимуться для визначення 3. середовище оцінювання, групу оцінювання, ролі й обов'язки з оцінювання. c. Забезпечити розгляд і затвердження плану оцінювання уповноваженою офіційною особою або призначеним для проведення оцінювання представником; d. Оцінити заходи захисту в системі та в її середовищі функціонування з [Призначення: визначеною організацією частотою] для визначення, наскільки коректно реалізовані заходи безпеки і чи працюють вони за призначенням і дають бажаний результат щодо дотримання встановлених вимог безпеки та приватності; e. Підготувати звіт оцінювання безпеки, який документує результати оцінювання; f. Надати результати оцінювання з безпеки [Призначення: особам або ролям, визначеним організацією].	CA-2	Моніторинг та авторизація компонентів ЄСІКС здійснюється на рівні інфраструктури безпеки, з регулярною перевіркою відповідності стандартам (OWASP Top 10, ДСТУ). Параметр: Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи заходи захисту та посилені заходи, що підлягають оцінюванню. CA-02(b)[02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання Тип: list Значення: admin, security_officer Параметр: Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03]

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до конфіденційності; СА-02(e) готується звіт оцінювання Тип: string Значення: щорічно Параметр: Результати оцінювання з безпеки надаються особам або ролям. оцінювання , який документує результати Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою слід оцінювати засоби контролю в системі та середовищі її функціонування Тип: integer Значення: 30 Параметр: Визначені особи або ролі, яким мають бути надані результати оцінювання з безпеки Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
61	ВЗАЄМОДІЯ СИСТЕМ (СА-3)	а. схвалити та керувати обміном інформацією між системою та іншими системами за допомогою [Вибір (один або кілька): угоди безпеки взаємозв'язку; договори безпеки обміну інформацією; меморандуми про взаєморозуміння; угоди про рівень обслуговування; угоди користувача; угоди про нерозголошення; [Доручення: тип договору, визначений організацією]]; б. документувати, як частину угоди про обмін, характеристики інтерфейсу, вимоги до безпеки та приватності, засоби контролю та відповідальність для кожної системи, а також характер переданої інформації; с. здійснювати перегляд та оновлення угод з [Призначення: визначеною організацією частотою].	СА-3	Моніторинг та авторизація компонентів ЄСІКС здійснюється на рівні інфраструктури безпеки, з регулярною перевіркою відповідності стандартам (OWASP Top 10, ДСТУ). Параметр: Характеристики інтерфейсу задокументовані як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Вимоги до безпеки задокументовані як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Вимоги щодо конфіденційності задокументовані як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Заходи захисту задокументовані як частина кожної угоди про обмін Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Відповідальність за кожну систему задокументована як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Характер переданої інформації документується як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Угоди переглядаються та оновлюються частота Тип: string Значення: щорічно Параметр: Визначено частоту, з якою необхідно переглядати та оновлювати угоди Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
62	ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (СА-5)	а. Розробити для системи план усунення недоліків та контрольні показники з метою документування запланованих коригувальних дій організації для усунення недоліків і зауважень, які виявлені в ході оцінювання заходів захисту, а також для зменшення або усунення відомих вразливостей у системі. б. Оновлювати чинний план усунення недоліків та контрольні показники з [Призначення: визначеною організацією частотою] на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу.	СА-5	Моніторинг та авторизація компонентів ЄСІКС здійснюється на рівні інфраструктури безпеки, з регулярною перевіркою відповідності стандартам (OWASP Top 10, ДСТУ). Параметр: Розроблено план усунення недоліків та контрольні показники для системи, та задокументовано заплановані дії організації з коригування, спрямовані на усунення недоліків та зауважень, виявлених під час оцінки заходів захисту, а також на зменшення або усунення відомих вразливостей в системі Тип: list Значення: login, logout, failed_attempt Параметр: Існуючий план оновлюються частота на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу Тип: string Значення: щорічно Параметр: Визначено частоту оновлення чинного плану усунення недоліків та контрольних показників на основі результатів оцінювання заходів захисту, незалежних аудитів та постійного моніторингу Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
63	БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (СА-7)	Розробити стратегію безперервного моніторингу безпеки та приватності й упровадити програму безперервного моніторингу безпеки та приватності, яка охоплює: а. встановлення показників безпеки та приватності, які необхідно відстежувати: [Призначення: визначені організацією метрики]; б. встановлення [Призначення: визначена організацією частота] для моніторингу та [Призначення: визначена організацією частота] для безперервного оцінювання ефективності заходів захисту; с. поточні оцінювання заходів захисту відповідно до стратегії безперервного моніторингу організації; д. постійний моніторинг стану безпеки та приватності відповідно до встановлених організацією метрик і відповідно до стратегії безперервного моніторингу організації; е. зіставлення та аналіз інформації, отриманої в результаті оцінювання та моніторингу безпеки та приватності; ф. дії реагування за результатами аналізу інформації, пов'язаної з безпекою та приватністю; г. повідомлення про статус безпеки та приватності системи [Призначення: визначені організацією персонал або ролі] з [Призначення: визначеною організацією частотою].	СА-7	Моніторинг та авторизація компонентів ЄСІКС здійснюється на рівні інфраструктури безпеки, з регулярною перевіркою відповідності стандартам (OWASP Top 10, ДСТУ). Параметр: Безперервний моніторинг на рівні системи включає встановлені частоти для моніторингу ефективності заходів захисту Тип: integer Значення: 30 Параметр: Безперервний моніторинг на рівні системи включає встановлені частоти для оцінки ефективності заходів захисту Тип: integer Значення: 30 Параметр: Безперервний моніторинг на рівні системи включає в себе дії з реагування на результати аналізу інформації, пов'язаної з безпекою та приватністю Тип: list Значення: login, logout, failed_attempt Параметр: Безперервний моніторинг на рівні системи включає повідомлення про статус безпеки системи для персоналу або ролей частота Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Безперервний моніторинг на рівні системи включає повідомлення про стан конфіденційності системи персоналу або ролям частота Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою слід моніторити ефективність заходів захисту Тип: integer Значення: 30 Параметр: Визначено частоту, з якою слід оцінювати ефективність заходів захисту Тип: integer Значення: 30 Параметр: Визначено персонал або ролі, яким повідомляється про стан безпеки системи Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою повідомляється про стан безпеки системи Тип: integer Значення: 30 Параметр: Визначено персонал або ролі, яким повідомляється про стан конфіденційності системи Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою повідомляється про стан конфіденційності системи Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
5. УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (СМ)				
64	Політика та процедури управління конфігурацією (СМ-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначених організацією персоналу або ролей]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики управління конфігурацією, яка: 2. (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, наказам, положенням, політикам, стандартам і керівним принципам; процедури, що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією. б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією. с. Переглядати та оновлювати поточну політику управління конфігурацією: 1. Політика [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].	СМ-1	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді. Параметр: Розроблено та задокументовано політику управління конфігурацією Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика управління конфігурацією поширюється на персонал або ролі Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури управління , що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією; СМ-01(с)[01][01] переглядається та оновлюється поточна політика управління конфігурацією частота; СМ-01(с)[01][02] переглядається та оновлюється поточна політика управління конфігурацією після події; СМ-01(с)[02][01] переглядаються та оновлюються поточні процедури управління конфігурацією частота;

48

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено персонал або ролі, на яких поширюється політика управління конфігурацією Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на яких поширюється процедури управління конфігурацією Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка управляє розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика управління конфігурацією Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено події, після яких переглядається та оновлюється поточна політика управління конфігурацією Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури управління конфігурацією Тип: integer Значення: 30 Параметр: Визначено події, після яких переглядаються та оновлюються поточні процедури управління конфігурацією Тип: list Значення: login, logout, failed_attempt
65	БАЗОВА КОНФІГУРАЦІЯ (СМ-2)	а. Розробити, задокументувати та підтримувати за допомогою заходів конфігурації поточні базові налаштування системи. б. Переглядати та оновлювати базові налаштування системи: - з [Призначення: визначеною організацією частотою]; - за потреби внаслідок [Призначення: визначених організацією обставин]; - коли встановлені нові або оновлені компоненти системи.	СМ-2	Файл 'erpuno.ex' фіксує єдину базову конфігурацію (Baseline) безпеки для всієї системи. Зміни в конфігурації застосовуються виключно через оновлення коду, що забезпечує строгий контроль та аудит змін. Параметр: baseline_configuration_code Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
66	БАЗОВА КОНФІГУРАЦІЯ - КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7))		СМ-2(7)	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді. Параметр: Системи або компоненти системи з конфігураціями видаються особам, що перебувають у місцях, які організація вважає, становлять значний ризик Тип: list Значення: admin, security_officer Параметр: Заходи безпеки застосовуються до систем або компонентів системи, коли особи повертаються з поїздки Тип: list Значення: admin, security_officer Параметр: Визначено системи або компоненти систем, які мають видаватися особам, що перебувають у місцях зі значним ризиком Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
67	УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)	а. Визначити типи змін у системі, які контролюються конфігурацією. б. Переглядати запропоновані зміни в конфігурації, контрольовані системою, і схвалити або відхилити ці зміни з явним урахуванням аналізу наслідків безпеки. с. Документувати рішення зі зміни конфігурації системи. д. Впровадити схвалені зміни конфігурації в систему. е. Зберігати записи змін конфігурації системі впродовж [Призначення: певного періоду часу, визначеного організацією]. ф. Здійснювати моніторинг і аналіз дій, пов'язаних зі змінами конфігурації системи. г. Координувати та впроваджувати нагляд за діяльністю з управління змінами конфігурації за допомогою [Призначення: елементу управління змінами конфігурації, визначеного організацією], який викликається [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: визначені організацією умови зміни конфігурації]].	СМ-3	Оскільки CMDB є частиною вихідного коду (Elixir модуль), всі зміни проходять через стандартний процес розробки (Code Review, CI/CD, контроль версій Git), унеможливаючи несанкціоноване втручання в налаштування на "живій" системі. Параметр: configuration_change_control Тип: boolean Значення: true
68	АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (СМ-4)	Аналізувати зміни в системі, щоб визначити потенційну загрозу безпеці та приватності перед реалізацією змін.	СМ-4	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді.
69	АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ - ВЕРИФІКАЦІЯ ФУНКЦІЙ БЕЗПЕКИ ТА ПРИВАТНОСТІ (СМ-4(2))		СМ-4(2)	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді.
70	ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)	Визначити, задокументувати, затвердити та забезпечити застосування фізичних і логічних обмежень доступу, пов'язаних зі змінами в системі.	СМ-5	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
71	НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6)	а. Встановити та задокументувати параметри конфігурації компонентів, які застосовуються в системі, які відображають найбільш обмежений режим, що відповідає експлуатаційним вимогам, використовуючи [Призначення: визначені організацією загальні безпечні конфігурації]. б. Реалізувати конфігураційні установки. с. Визначити, задокументувати та затвердити будь-які відхилення від встановлених конфігураційних параметрів конфігурації для [Призначення: визначених організацією компонентів системи] на основі [Призначення: визначених організацією експлуатаційних вимог]. д. Відстежувати та керувати змінами конфігураційних параметрів відповідно до організаційної політики та процедур.	СМ-6	Параметри політик безпеки та їхні значення за замовчуванням жорстко зашиті в 'egrupo.ex'. Компілятор генерує незмінний об'єктний файл, який гарантує виконання затверджених налаштувань під час роботи. Параметр: compile_time_config Тип: boolean Значення: true
72	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ (СМ-7)	а. Налаштуйте систему для забезпечення лише [Призначення: основні функції, визначені організацією для місії]; б. Заборонити або обмежити використання таких функцій, портів, протоколів, програмного забезпечення та/або служб: [Призначення: визначені організацією заборонені або обмежені функції, системні порти, протоколи, програмне забезпечення та/або служби].	СМ-7	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ICC. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді. Параметр: Використання протоколи заборонено або обмежено Тип: string Значення: TLS 1.3 Параметр: Визначено протоколи, які необхідно заборонити або обмежити; СМ-07_ODP[05] визначено програмне забезпечення, яке необхідно заборонити або обмежити Тип: string Значення: TLS 1.3

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
73	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ - ПЕРІОДИЧНИЙ ПЕРЕГЛЯД (СМ-7(1))		СМ-7(1)	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді. Параметр: Система переглядається частота для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг Тип: string Значення: TLS 1.3 Параметр: Протоколи, які вважаються непотрібними та/або незахищеними, вимкнено Тип: string Значення: TLS 1.3 Параметр: Визначено частоту, з якою слід переглядати систему для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг Тип: string Значення: TLS 1.3 Параметр: Визначено протоколи, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними Тип: string Значення: TLS 1.3

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
74	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ - АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5))		СМ-7(5)	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді. Параметр: Політика "заборонити все, дозволити за винятком" застосовується, щоб дозволити виконання авторизованих програм у системі Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Переглядається та оновлюється список авторизованих програм частота Тип: list Значення: Параметр: Визначено частоту перегляду та оновлення списку авторизованих програм Тип: integer Значення: 30
75	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (СМ-8)	а. б. Розробити та задокументувати процес інвентаризації компонентів системи, який: 1. точно описує поточну систему; 2. охоплює всі компоненти в межах акредитації системи; 3. не включає повторний облік компонентів або компонентів, будь-якої іншої системи; 4. визначає рівень деталізації, який є необхідним для відстеження та звітування; 5. включає інформацію для досягнення підзвітності компонентів системи: [Призначення: визначена організацією інформація, необхідна для досягнення ефективної підзвітності компонентів системи]. Переглядати та оновлювати опис компонентів системи з [Призначення: визначеною організацією частотою].	СМ-8	Профіль автоматично фіксує перелік використовуваних компонентів системи (бібліотеки 'synrc/kvs', 'synrc/ca' тощо) та їхні параметри, забезпечуючи інтегральну інвентаризацію модулів захисту. Параметр: component_inventory Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
76	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ - ОНОВЛЕННЯ ПІД ЧАС ВСТАНОВЛЕННЯ ТА ВИДАЛЕННЯ (СМ-8(1))		СМ-8(1)	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді.
77	РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12)		СМ-12	Управління конфігураціями та оновленнями (СМ) здійснюється згідно з політиками ІСС. Вразливі компоненти оновлюються протягом 5 днів після виявлення в exploit-db. Конфігураційні файли зберігаються в зашифрованому вигляді.
6. ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (СР)				
78	РЕЗЕРВНЕ КОПЮВАННЯ (СР-9)		СР-9	Система здійснює автоматичне створення резервних копій бази даних KVS. Бекапи можуть зберігатися локально або відправлятися до хмарних сховищ, гарантуючи відновлення даних відповідно до RTO/RPO. Параметр: system_backup Тип: boolean Значення: true
79	РЕЗЕРВНЕ КОПЮВАННЯ - КРИПТОГРАФІЧНИЙ ЗАХИСТ (СР-9(8))		СР-9(8)	Безперервність роботи та резервне копіювання забезпечується кластеризацією сховищ даних (LSM-дерева, реплікація PostgreSQL) та регулярним копіюванням БД і журналів згідно з політиками ЄСІКС. Параметр: Реалізовано криптографічні механізми для запобігання несанкціонованому розкриттю та зміні резервної інформації Тип: string Значення: AES-256-GCM

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
7. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (IA)				
80	Політика та процедури ідентифікації та автентифікації (IA-1)		IA-1	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Розроблено та задокументовано політику ідентифікації та автентифікації Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика ідентифікації та автентифікації поширюється на персонал або ролі Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури ідентифікації та автентифікації, що сприяють впровадженню політики ідентифікації та автентифікації, а також відповідні заходи ідентифікації та перевірки автентичності Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління політикою та процедурами ідентифікації та автентифікації; IA-01(c)[01][01] переглядається та оновлюється поточна політика ідентифікації та автентифікації частота; IA-01(c)[01][02] переглядається та оновлюється поточна політика ідентифікації та автентифікації після подій; IA-01(c)[02][01] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації

57

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено персонал або ролі, на які поширюється політика ідентифікації та автентифікації Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури ідентифікації та автентифікації Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка управляє політикою та процедурами ідентифікації та автентифікації Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика ідентифікації та автентифікації Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено події, які потребують перегляду та оновлення поточної політики ідентифікації та автентифікації Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури ідентифікації та автентифікації Тип: integer Значення: 30 Параметр: Визначено події, які потребують перегляду та оновлення процедур ідентифікації та автентифікації Тип: list Значення: login, logout, failed_attempt
81	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (IA-2)		IA-2	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: org_user_auth Тип: boolean Значення: true
82	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (IA-2(1))		IA-2(1)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.
83	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ НЕПРИВІЛЕЙОВАНИХ (IA-2(2))		IA-2(2)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
84	Ідентифікація та автентифікація (користувачів організації) - Доступ до облікових записів — стійкість до відтворення (IA-2(8))		IA-2(8)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.
85	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ПРИЙНЯТТЯ ПОВНОВАЖЕНЬ ДЛЯ ВЕРИФІКАЦІЇ ОСОБИСТОЇ ІНФОРМАЦІЇ (PIV CREDENTIALS) (IA-2(12))		IA-2(12)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Приймаються та електронним шляхом підтверджуються повноваження облікових даних особистої ідентифікації Тип: list Значення: admin, security_officer
86	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (IA-3)		IA-3	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
87	УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (IA-4)		IA-4	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Управління ідентифікаторами здійснюється шляхом отримання дозволу від персоналу або ролей на призначення ідентифікатора особі, групі, ролі або пристрою Тип: list Значення: admin, security_officer Параметр: Управління ідентифікаторами здійснюється шляхом вибору ідентифікатора, який ідентифікує окрему особу, групу, ролі або пристрій Тип: list Значення: admin, security_officer Параметр: Управління ідентифікаторами здійснюється шляхом призначення ідентифікатора особі, групі, ролі або пристрою; IA-04(d) ідентифікатори управляються шляхом запобігання повторному використанню ідентифікаторів впродовж період часу Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, від яких необхідно отримати дозвіл на призначення ідентифікатора Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено період часу для запобігання повторному використанню ідентифікаторів Тип: integer Значення: 30
88	УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ - ІДЕНТИФІКАЦІЯ СТАТУСУ КОРИСТУВАЧА (IA-4(4))		IA-4(4)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.
89	АВТЕНТИФІКАТОР УПРАВЛІННЯ		IA-5	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Управління системними автентифікаторами здійснюється шляхом перевірки, як частини початкового розподілу автентифікатора, особи, групи, ролі або пристрою, який отримує автентифікатор Тип: list Значення: admin, security_officer Параметр: Управління системними автентифікаторами здійснюється шляхом зміни/оновлення автентифікаторів у встановлений період часу або коли відбуваються події Тип: list Значення: login, logout, failed_attempt Параметр: Визначено період часу для зміни або оновлення автентифікаторів за типом автентифікатора Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
90	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (IA-5(1))		IA-5(1)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Для автентифікації на основі паролів підтримується та оновлюється список часто використовуваних, очікуваних або скомпрометованих паролів частота, а також коли є підозра, що паролі організації були скомпрометовані прямо чи опосередковано Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі паролів, коли паролі створюються або оновлюються користувачами, паролі перевіряються на відсутність у списку загальноновживаних, очікуваних або скомпрометованих паролів в IA-05(01)(a) Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі паролів, паролі передаються лише криптографічно захищеними каналами Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі паролів паролі зберігаються за допомогою затвердженого алгоритму гешування, переважно використовуючи ключову геш-функцію Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Для автентифікації на основі пароля дозволяється вибір користувачем довгих паролів і фраз, що включають пробіли та всі друковані символи Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі пароля використовуються автоматизовані інструменти, які допомагають користувачеві у виборі надійних автентифікаторів паролів Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі пароля застосовуються склад та правила складності Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту оновлення списку часто використовуваних, очікуваних або скомпрометованих паролів Тип: list Значення: admin, security_officer Параметр: Визначено склад та правила складності автентифікатора Тип: list Значення: default_deny_rule, abac_rule_1
91	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ ВІДКРИТОГО КЛЮЧА (IA-5(2))		IA-5(2)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
92	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ АПАРАТНИХ ТОКЕНІВ (IA-5(11))		IA-5(11)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.
93	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - ЕФЕКТИВНІСТЬ БІОМЕТРИЧНОЇ АВТЕНТИФІКАЦІЇ (IA-5(12))		IA-5(12)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Визначено вимоги до якості біометрії; для біометричної автентифікації використовувати механізми, які задовольняють вимоги Тип: string Значення: автоматизований засіб моніторингу
94	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - ПРОДУКТИ ТА ПОСЛУГИ, ЗАТВЕРДЖЕНІ УПОВНОВАЖЕНИМ ОРГАНОМ (IA-5(15))		IA-5(15)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.
95	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТОМАТИЗОВАНІ ЗАСОБИ ВИЯВЛЕННЯ АТАК ІЗ ВИКОРИСТАННЯМ БІОМЕТРИЧНИХ АВТЕНТИФІКАТОРІВ (IA-5(17))		IA-5(17)	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Використовуються механізми виявлення атак із використанням штучно виготовлених артефактів для біометричних автентифікаторів Тип: string Значення: автоматизований засіб моніторингу

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
96	ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА		IA-6	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Забезпечено приховану зворотну передачу інформації автентифікації в процесі автентифікації для забезпечення захисту інформації від можливої експлуатації та використання неавторизованими особами Тип: list Значення: admin, security_officer
97	АВТЕНТИФІКАЦІЯ КРИПТОГРАФІЧНОГО МОДУЛЯ (IA-7)		IA-7	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією. Параметр: Впроваджено механізми автентифікації в криптографічний модуль, який відповідає вимогам чинних законів, виконавчих розпоряджень, директив, політик, правил, стандартів та рекомендацій для такої автентифікації Тип: list Значення: default_deny_rule, abac_rule_1
98	ПОВТОРНА АВТЕНТИФІКАЦІЯ (IA-11)		IA-11	Ідентифікація та автентифікація в ЄСІКС вимагає обов'язкового використання КЕП на захищеному носії (ДСТУ 4145:2002) з форматом CAdES-X Long та SSO інтеграцією.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
8. РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR)				
99	Політика та процедури реагування на інциденти (IR-1)		IR-1	Політика реагування на інциденти задована безпосередньо у бізнес-процесах (BPMN) ‘erpuno/itsm’, забезпечуючи неухильне виконання процедур на кожному кроці життєвого циклу інциденту. Параметр: incident_policy_enforcement Тип: boolean Значення: true
100	НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)		IR-2	Інтерфейс ‘erpuno/itsm’ надає контекстні підказки та інструкції безпосередньо у формах обробки інцидентів, що виконує функцію інтерактивного навчання та підтримки персоналу в кризових ситуаціях. Параметр: incident_response_training Тип: boolean Значення: true
101	ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)		IR-3	Можливості ВРЕ-движка дозволяють запускати симуляції інцидентів у тестовому середовищі ‘itsm’ для регулярного тестування планів реагування без впливу на продуктивну систему. Параметр: incident_testing_simulation Тип: boolean Значення: true
102	Обробка інциденту (IR-4)		IR-4	Будь-який інцидент безпеки автоматично реєструється як тикет у модулі ‘itsm’. Процес обробки (‘incident_management_process’) гарантує, що інцидент пройде всі необхідні етапи: виявлення, ізоляція, усунення, відновлення. Параметр: incident_handling Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
103	Моніторинг інциденту (IR-5)		IR-5	Статуси інцидентів у реальному часі відображаються на дашбордах 'erpuno/itsm'. ВРЕ-движок дозволяє призначати SLA-таймаути (Boundary Events) для ескалації інцидентів, якщо час реакції перевищено. Параметр: incident_monitoring Тип: boolean Значення: true
104	ЗВІТНІСТЬ ПРО ІНЦИДЕНТИ (IR-6)		IR-6	Система 'erpuno/itsm' автоматично формує звіти про інциденти, надаючи вичерпну інформацію про порушені сервіси, час простою (SLA) та дії команди, що закриває вимоги внутрішньої та зовнішньої звітності. Параметр: automated_incident_reporting Тип: boolean Значення: true
105	ПІДТРИМКА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-7)		IR-7	Вбудовані засоби комунікації в рамках тикету (коментарі, призначення експертів, інтеграція з базою знань) забезпечують оперативну допомогу та координацію групи безпеки під час інциденту. Параметр: incident_assistance Тип: boolean Значення: true
106	План реагування на інциденти (IR-8)		IR-8	Сам конфігураційний код процесів 'erpuno/itsm' виступає в ролі актуального та виконуваного плану реагування на інциденти (Executable Incident Response Plan), усуваючи розбіжність між документацією та реальністю. Параметр: executable_ir_plan Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
9. ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ (МА)				
107	ПОЛІТИКА ТА ПРОЦЕДУРИ ТЕХНІЧНОГО ОБСЛУГОВУВАННЯ (МА-1)	а. Планувати, документувати та переглядати записи з технічного обслуговування, ремонту або заміни компонентів системи відповідно до вимог виробника та постачальників та/або вимог організації. b. Затвердити та здійснювати моніторинг усіх заходів з технічного обслуговування, незалежно від того, виконуються вони на місці або віддалено, а також чи обслуговуються системи або системні компоненти на місці, чи переміщуються в інше місце. с. Вимагати, щоб [Призначення: визначені організацією персонал чи ролі] явно схвалили видалення системи або компоненту системи з організаційного обладнання для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації. d. Очищати обладнання з погляду видалення всієї інформації з носіїв до вилучення обладнання організації для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації. е. Перевірити всі потенційно порушені заходи захисту, щоб переконатися, що вони, як і раніше, працюють належним чином після дій з обслуговування, ремонту або заміни. f. Вносити [Призначення: визначену організацією інформацію, пов'язану з технічним обслуговуванням] до записів з технічного обслуговування.	МА-1	Технічне обслуговування компонентів ЄСІКС здійснюється авторизованим персоналом (ІСС) через безпечні канали з відповідним логуванням дій. Параметр: Розроблено та задокументовано політику технічного обслуговування Тип: list Значення: default _ deny _ rule, abac _ rule _ 1 Параметр: Політика технічного обслуговування поширюється на персонал або ролі Тип: list Значення: admin, security _ officer Параметр: Розроблені та задокументовані процедури технічного обслуговування, що сприяють впровадженню політики технічного обслуговування та пов'язаних з нею заходів технічного обслуговування Тип: list Значення: default _ deny _ rule, abac _ rule _ 1 Параметр: Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур технічного обслуговування; МА-01(с)[01][01] переглядається та оновлюється поточна політика обслуговування частота; МА-01(с)[01][02] переглядається та оновлюється поточна політика обслуговування після подій; МА-01(с)[02][01] переглядаються та оновлюються поточні процедури технічного обслуговування частота; МА-01(с)[02][02] переглядаються та оновлюються поточні процедури технічного

69

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено персонал або ролі, на які поширюється політика технічного обслуговування Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури технічного обслуговування Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами технічного обслуговування Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика технічного обслуговування Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено події, які потребують перегляду та оновлення поточної політики технічного обслуговування Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури технічного обслуговування Тип: integer Значення: 30 Параметр: Визначено події, які потребують перегляду та оновлення процедур технічного обслуговування Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
108	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)	а. Затвердити, контролювати та відстежувати використання засобів технічного обслуговування. б. Переглядати раніше затверджені інструменти технічного [Призначення: з частотою, визначеною організацією]. обслуговування	МА-3	Технічне обслуговування компонентів ЄСІКС здійснюється авторизованим персоналом (ІСС) через безпечні канали з відповідним логуванням дій. Параметр: Переглядаються раніше затверджені інструменти технічного обслуговування частота Тип: string Значення: щорічно Параметр: Визначено частоту, з якою слід переглядати раніше затверджені інструменти технічного обслуговування Тип: integer Значення: 30
109	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ - ПЕРЕВІРКА ІНСТРУМЕНТІВ (МА-3(1))		МА-3(1)	Технічне обслуговування компонентів ЄСІКС здійснюється авторизованим персоналом (ІСС) через безпечні канали з відповідним логуванням дій. Параметр: Оглядаються інструменти для технічного обслуговування, які доставлені на об'єкт обслуговуючим персоналом, на предмет неправильних або несанкціонованих модифікацій Тип: list Значення: admin, security_officer
110	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ - ПЕРЕВІРКА НОСІЇВ ІНФОРМАЦІЇ (МА-3(2))		МА-3(2)	Технічне обслуговування компонентів ЄСІКС здійснюється авторизованим персоналом (ІСС) через безпечні канали з відповідним логуванням дій.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
111	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ - ЗАПОБІГАННЯ НЕСАНКЦІОНОВАНОМУ ПЕРЕМІЩЕННЮ (МА-3(3))		МА-3(3)	Технічне обслуговування компонентів ЄСІКС здійснюється авторизованим персоналом (ІСС) через безпечні канали з відповідним логуванням дій. Параметр: Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом отримання дозволу від персоналу або ролі Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, які можуть надавати дозвіл на переміщення обладнання з об'єкту Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
112	ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)		МА-4	Технічне обслуговування компонентів ЄСІКС здійснюється авторизованим персоналом (ІСС) через безпечні канали з відповідним логуванням дій. Параметр: Впроваджено віддалені дії з обслуговування та діагностики Тип: list Значення: login, logout, failed_attempt Параметр: Відстежуються віддалені дії з обслуговування та діагностики Тип: list Значення: login, logout, failed_attempt Параметр: Використання віддалених засобів технічного обслуговування та діагностики дозволено лише відповідно до політики організації Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
113	ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)	а. Встановити процедуру авторизації технічного персоналу та вести перелік авторизованих організацій технічного обслуговування або персоналу. б. Перевіряти, що персонал, який не супроводжується та виконує технічне обслуговування в системі, має необхідні дозволи на доступ. с. Визначити персонал організації з необхідними повноваженнями щодо доступу та технічною компетенцією для нагляду за персоналом з технічного обслуговування, який не має необхідних дозволів на доступ.	МА-5	Технічне обслуговування компонентів ЄСІКС здійснюється авторизованим персоналом (ІСС) через безпечні канали з відповідним логуванням дій. Параметр: Запроваджено процес авторизації технічного персоналу Тип: list Значення: admin, security_officer Параметр: Ведеться перелік авторизованих організацій або персоналу з технічного обслуговування Тип: list Значення: admin, security_officer Параметр: Персонал без супроводу, який виконує технічне обслуговування системи, має необхідні дозволи на доступ Тип: list Значення: admin, security_officer Параметр: Персонал організації з необхідними повноваженнями доступу та технічною компетентністю призначений/призначені для нагляду за діяльністю з технічного обслуговування персоналу, який не має необхідних дозволів на доступ Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
10. ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ (МР)				
114	ПОЛІТИКА ТА ПРОЦЕДУРИ ЩОДО ЗАХИСТУ НОСІЇВ ІНФОРМАЦІЇ (МР-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]: 1. 2. політику захисту носіїв інформації, яка: (а) містить мету, сферу застосування, ролі, обов’язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, які сприяють здійсненню політики та заходів захисту носіїв інформації. б. Призначити [Призначення: визначену організацією посадову особу] для управління розробкою, документування, та розповсюдження політики та процедурами захисту носіїв інформації. с. Переглядати та оновлювати чинну систему захисту носіїв інформації: 1. поточну політику захисту носіїв інформації [Призначення: з визначеною організацією частотою]; 2. поточні процедури захисту носіїв інформації [Призначення: з визначеною організацією частотою].	МР-1	Криптографічні ключі та сертифікати зберігаються на захищених апаратних носіях (HSM) або в зашифрованих сховищах, доступ до яких обмежено. Параметр: Розроблено та задокументовано політику захисту носіїв інформації Тип: list Значення: default _ deny_rule, abac_rule_1 Параметр: Політика захисту носіїв інформації поширюється на персонал або ролі Тип: list Значення: admin, security_officer Параметр: Розроблено та задокументовано процедури захисту носіїв інформації, що сприятимуть реалізації політики захисту носіїв інформації та заходів захисту носіїв інформації Тип: list Значення: default _ deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур захисту носіїв інформації. МР-01(с)[01][01] переглядається та оновлюється поточна політика захисту носіїв інформації частота; МР-01(с)[01][02] переглядається та оновлюється поточна політика захисту носіїв інформації після подій; МР-01(с)[02][01] переглядаються та оновлюються поточні процедури захисту носіїв інформації частота; МР-01(с)[02][02] переглядаються та оновлюються поточні процедури захисту носіїв інформації після подій;

75

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено персонал або ролі, серед яких має бути поширена політика захисту носіїв інформації Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, серед яких мають бути поширені процедури захисту носіїв інформації Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами захисту носіїв інформації Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика захисту носіїв інформації Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено події, які потребують перегляду та оновлення чинної політики захисту носіїв інформації Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються чинні процедури захисту носіїв інформації Тип: integer Значення: 30 Параметр: Визначено події, які потребують перегляду та оновлення процедур захисту носіїв інформації Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
115	ДОСТУП ДО НОСІВ ІНФОРМАЦІЇ (МР-2)	Обмежити доступ до [Призначення: визначених організацією типів цифрових та/або нецифрових носіїв інформації] [Призначення: визначеним організацією персоналом або ролями].	МР-2	Криптографічні ключі та сертифікати зберігаються на захищених апаратних носіях (HSM) або в зашифрованих сховищах, доступ до яких обмежено. Параметр: Доступ до типів цифрових носіїв інформації обмежено для персоналу або ролей Тип: list Значення: admin, security_officer Параметр: Доступ до типів нецифрових носіїв інформації обмежено для персоналу або ролей Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, уповноважені на доступ до цифрових носіїв інформації Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, уповноважені на доступ до нецифрових носіїв інформації Тип: list Значення: admin, security_officer
116	МАРКУВАННЯ НОСІВ ІНФОРМАЦІЇ (МР-3)	а. Наносити на носії інформації маркування, що вказують на обмеження поширення, обробки, а також застереження та відповідні мітки безпеки (якщо такі є) інформації. б. Звільнити [Призначення: визначені організацією типи носіїв системи] від маркування, якщо носії залишаються в межах [Призначення: визначених організацією контрольованих зон].	МР-3	Криптографічні ключі та сертифікати зберігаються на захищених апаратних носіях (HSM) або в зашифрованих сховищах, доступ до яких обмежено. Параметр: Визначено типи носіїв інформації, які звільняються від маркування під час перебування на контрольованих зонах Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
117	ЗБЕРІГАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-4)	а. Фізично контролювати та безпечно зберігати [Призначення: визначені організацією типи цифрових та/або нецифрових носіїв інформації] в межах [Призначення: визначених організацією контрольованих зон]. б. Захищати системні носії, які визначені в МР-4 до того часу, як носії знищуються або очищаються, з використанням затвердженого обладнання, методів та процедур.	МР-4	Криптографічні ключі та сертифікати зберігаються на захищених апаратних носіях (HSM) або в зашифрованих сховищах, доступ до яких обмежено.
118	Транспортування носіїв інформації (МР-5)	а. Захищати та контролювати [Призначення: визначені організацією типи носіїв системи] під час транспортування за межами контрольованих зон, використовуючи [Призначення: визначені організацією заходи безпеки]. б. Вести облік носіїв системи інформації під час транспортування за межами контрольованих зон. с. Документувати дії, пов'язані з транспортуванням носіїв системи. д. Обмежити діяльність уповноваженого персоналу, пов'язану з транспортуванням носіїв системи.	МР-5	Криптографічні ключі та сертифікати зберігаються на захищених апаратних носіях (HSM) або в зашифрованих сховищах, доступ до яких обмежено. Параметр: Типи носіїв інформації системи захищаються під час транспортування за межі контрольованих зон за допомогою заходів безпеки Тип: integer Значення: 30 Параметр: Типи носіїв інформації системи контролюються під час транспортування за межі контрольованих зон за допомогою заходів безпеки Тип: integer Значення: 30 Параметр: Під час транспортування за межі контрольованих зон ведеться облік носіїв інформації системи Тип: integer Значення: 30 Параметр: Визначено персонал, уповноважений здійснювати діяльність з транспортування носіїв інформації Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Діяльність, пов'язана з транспортуванням носіїв інформації системи, обмежується визначеним уповноваженим персоналом Тип: list Значення: admin, security_officer Параметр: Визначено типи носіїв інформації системи для захисту та контролю під час транспортування за межі контрольованих зон Тип: integer Значення: 30
119	ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (МР-6)	а. Очищувати [Призначення: визначені організацією системні носії] перед утилізацією, випуском за межі організаційного контролю, або перед повторним використанням [Призначення: методами та процедурами очищення, визначеними організацією]. б. Використовувати механізми очищення зі стійкістю та цілісністю, що відповідає категорії безпеки або рівню секретності інформації.	МР-6	Криптографічні ключі та сертифікати зберігаються на захищених апаратних носіях (HSM) або в зашифрованих сховищах, доступ до яких обмежено. Параметр: Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації Тип: string Значення: автоматизований засіб моніторингу
120	ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-7)	а. [Вибір: обмежити; заборонити] використання [Призначення: визначених організацією типів носіїв системи] на [Призначення: визначені організацією системи або компоненти системи], використовуючи [Призначення: визначені організацією заходи безпеки]. б. Заборонити використання портативних пристроїв зберігання даних в системах організації, якщо такі пристрої не мають визначеного власника.	МР-7	Криптографічні ключі та сертифікати зберігаються на захищених апаратних носіях (HSM) або в зашифрованих сховищах, доступ до яких обмежено.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
121	ЗНИЖЕННЯ КАТЕГОРІЇ БЕЗПЕКИ НОСІЇВ ІНФОРМАЦІЇ - ТАЄМНА ІНФОРМАЦІЯ (МР-8(4))		МР-8(4)	Криптографічні ключі та сертифікати зберігаються на захищених апаратних носіях (HSM) або в зашифрованих сховищах, доступ до яких обмежено. Параметр: Носії інформації, що містять інформацію з обмеженим доступом, знижуються в класі перед передачею особам, які не мають необхідних дозволів на доступ Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
11. ФІЗИЧНИЙ ЗАХИСТ ТА ЗАХИСТ НАВКОЛИШНЬОГО СЕРЕДОВИЩА (РЕ)				
122	РЕ-1 фізичного захисту та захисту робочого середовища Авторизація фізичного (РЕ-1)		РЕ-1	Фізичний захист серверного обладнання та носіїв інформації забезпечується центрами обробки даних (ЦОД) ЄСІКС з багаторівневим контролем доступу. Параметр: Розроблено та задокументовано політику фізичного захисту та захисту робочого середовища Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Політика фізичного захисту та захисту робочого середовища розповсюджується серед персоналу або ролей Тип: list Значення: admin, security_officer Параметр: Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур фізичного захисту та захисту робочого середовища; РЕ-01(с)[01][01] переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища частота; РЕ-01(с)[01][02] поточна політика фізичного захисту та захисту робочого середовища переглядається та оновлюється після подій; РЕ-01(с)[02][01] переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища частота; поточні процедури фізичного та екологічного захисту переглядаються та оновлюються після подій. РЕ-01(с)[02][02] Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, до яких має бути

81

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Визначено персонал або ролі, на які поширюються процедури фізичного захисту та захисту робочого середовища Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами фізичного захисту та захисту робочого середовища Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено події, які потребують перегляду та оновлення поточної політики фізичного захисту та захисту робочого середовища Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища Тип: integer Значення: 30 Параметр: Визначено події, які потребують перегляду та оновлення процедур фізичного захисту та захисту робочого середовища Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
123	РЕ-2 доступу (РЕ-2)		РЕ-2	Регламентується інструкціями з режиму ЦОД (див. розділ РЕ у digital-profile.pdf). Параметр: physical_access_doc_ref Тип: string Значення: digital-profile.pdf
124	ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ		РЕ-3	Регламентується системами СКУД будівлі (див. розділ РЕ у digital-profile.pdf). Параметр: physical_access_control_ref Тип: string Значення: digital-profile.pdf
125	РЕ-4 ліній електроживлення (РЕ-4)		РЕ-4	Фізичний захист серверного обладнання та носіїв інформації забезпечується центрами обробки даних (ЦОД) ЄСІКС з багаторівневим контролем доступу.
126	КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОБРАЖЕННЯ ІНФОРМАЦІЇ		РЕ-5	Фізичний захист серверного обладнання та носіїв інформації забезпечується центрами обробки даних (ЦОД) ЄСІКС з багаторівневим контролем доступу.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
127	МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ		РЕ-6	Фізичний захист серверного обладнання та носіїв інформації забезпечується центрами обробки даних (ЦОД) ЄСІКС з багаторівневим контролем доступу. Параметр: Переглядаються журнали фізичного доступу частота Тип: string Значення: щорічно Параметр: Визначено частоту перегляду журналів фізичного доступу Тип: integer Значення: 30 Параметр: Визначено події або потенційні ознаки подій, що вимагають перегляду журналів фізичного доступу Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
128	АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (PE-17)		PE-17	Фізичний захист серверного обладнання та носіїв інформації забезпечується центрами обробки даних (ЦОД) ЄСІКС з багаторівневим контролем доступу. Параметр: Визначаються заходи захисту, які будуть застосовуватися на альтернативних робочих місцях; PE-17(a) альтернативні робочі місця визначені та задокументовані; PE-17(b) заходи захисту впроваджені на альтернативних робочих місцях; PE-17(c) оцінюється ефективність заходів захисту на альтернативних робочих місцях; PE-17(d) працівникам надаються засоби комунікації з персоналом служби інформаційної безпеки на випадок інцидентів Тип: list Значення: admin, security officer
129	МАРКУВАННЯ КОМПОНЕНТІВ (PE-22)		PE-22	Фізичний захист серверного обладнання та носіїв інформації забезпечується центрами обробки даних (ЦОД) ЄСІКС з багаторівневим контролем доступу.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
12. ПЛАНУВАННЯ (PL)				
130	ПОЛІТИКИ ТА ПРОЦЕДУРИ ПЛАНУВАННЯ БЕЗПЕКИ (PL-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]: 1. 2. [вибір (один або декілька): рівень організації; рівень місії/бізнес процесу; рівень системи] політику планування, яка: (а) містить мету, сферу застосування, ролі, обов’язки, відповідальність керівництва, координацію між організаційними підрозділами та системою контролю (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, що полегшують здійснення планування політики безпеки та приватності й пов’язані з ними заходи. б. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами планування політики безпеки та приватності. с. Переглядати та оновлювати поточне планування: 1. політики планування безпеки та приватності [Призначення:з визначеною організацією частотою] та наступні [Призначення: визначені організацією події]; 2. поточні процедури планування політики [Призначення: з визначеною організацією [Призначення: визначені організацією події]. безпеки та приватності частотою] та наступні	PL-1	Планування архітектури та безпеки базується на методології ISO/IEC/IEEE 42010, фреймворку Закмана та ДСТУ. Параметр: Визначено персонал або ролі, до яких має бути доведена політика планування безпеки Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюватимуться процедури планування безпеки Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами планування безпеки Тип: list Значення: admin, security_officer Параметр: Визначено періодичність перегляду та оновлення поточної політики планування безпеки Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які потребують перегляду та оновлення поточної політики планування безпеки Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначена частота, з якою переглядаються та оновлюються поточні процедури планування безпеки Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
131	ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2)	а. Розробити план захисту інформації та персональних даних для інформаційної системи, який: 1. узгоджується з архітектурою підприємства організації; 2. чітко визначає складові компоненти системи; 3. описує оперативний контекст інформаційної системи з точки зору завдань та процесів; 4. визначає осіб, які виконують системні ролі та обов'язки; 5. визначає тип інформації, яка обробляється, зберігається та передається системою; 6. надає огляд вимог безпеки та приватності інформаційної системи; 7. описує будь які конкретні загрози системи, які викликають стурбованість організації; 8. надає результати оцінки ризику конфіденційності для систем, в яких обробляються персональні дані; 9. описує робоче середовище інформаційної системи та будь які залежності від систем або компонентів систем або підключень до таких систем та їх компонентів; 10. надає огляд вимог безпеки та конфіденційності системи; 11. визначає будь які відповідні контрольні базові рівні або накладання, якщо вони застосовуються; 12. описує чинні або заплановані заходи щодо забезпечення безпеки та приватності, включно з обґрунтуванням рішень щодо налаштування 13. включає виявлення ризиків для архітектури безпеки і приватності, а також проектних рішень; 14. включає дії, пов'язані з безпекою та конфіденційністю, які впливають на систему, виконання яких вимагає планування та координацію з [Призначення: визначені організацією окремі особи або групи]; 15. розглядається та затверджується уповноваженою посадовою особою або призначеним представником до початку реалізації плану. б. Поширити копії планів захисту інформації та персональних даних і повідомляти про подальші зміни планів серед [Призначення: визначеного організацією персоналу або ролей]. с. Переглядати плани захисту інформації та персональних даних [Призначення: з визначеною організацією частотою]. д. Оновлювати плани захисту інформації та персональних даних для врахування змін в інформаційній системі й робочому середовищі або проблем, виявлених у ході реалізації або оцінювання заходів безпеки та приватності. е. забезпечити захист планів захисту інформації та персональних даних від несанкціонованого розголошення та змін.	PL-2	Планування архітектури та безпеки базується на методології ISO/IEC/IEEE 42010, фреймворку Закмана та ДСТУ. Параметр: system_security_plan Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
132	ПРАВИЛА ПОВЕДІНКИ (PL-4)	а. Створити та надати особам, що потребують доступу до інформаційної системи, правила, які описують їхні обов'язки й очікувану поведінку щодо інформації та використання інформаційної системи, безпеки та приватності. б. Отримати документальне підтвердження від таких осіб про те, що вони прочитали, зрозуміли та погодилися дотримуватися правил поведінки, перш ніж дозволяти доступ до інформації та інформаційної системи. с. Переглядати й оновлювати правила поведінки [Призначення: з визначеною організацією частотою]. д. Вимагати від осіб, які підписали попередню версію правил поведінки, перечитати та повторно підписати правила [Вибір (один або декілька): [Призначення: з визначеною організацією частотою]; коли правила переглядаються чи оновлюються].	PL-4	Планування архітектури та безпеки базується на методології ISO/IEC/IEEE 42010, фреймворку Закмана та ДСТУ. Параметр: rules_of_behavior Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
13. БЕЗПЕКА ПЕРСОНАЛУ (PS)				
133	Політика та процедури кадрової безпеки (PS-1)		PS-1	Вимоги до безпеки персоналу визначаються політиками управління кадрами та процедурами допуску до інформації в системі ЄСІКС. Параметр: Визначено персонал або ролі, на які поширюється політика кадрової безпеки Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури кадрової безпеки Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами кадрової безпеки Тип: list Значення: admin, security_officer Параметр: Визначена періодичність перегляду та оновлення поточної політики кадрової безпеки Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які вимагають перегляду та оновлення поточної політики кадрової безпеки Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено періодичність перегляду та оновлення поточних процедур кадрової безпеки Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
134	Перевірка персоналу (PS-3)		PS-3	Вимоги до безпеки персоналу визначаються політиками управління кадрами та процедурами допуску до інформації в системі ЄСІКС. Параметр: Визначені умови, що вимагають повторної перевірки осіб Тип: list Значення: Параметр: Визначена частота повторної перевірки осіб, для яких це показано; PS-03a. проходять особи перевірку перед тим, як надати їм доступ до системи; PS-03b.[01] проходять особи повторну перевірку відповідно до умови, що вимагають повторної перевірки; PS-03b.[02] проводиться повторна перевірка у випадках, коли це зазначено, частота Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
135	Звільнення персоналу (PS-4)		PS-4	Вимоги до безпеки персоналу визначаються політиками управління кадрами та процедурами допуску до інформації в системі ЄСІКС. Параметр: Визначено період часу, протягом якого забороняється доступ до системи Тип: integer Значення: 30 Параметр: Визначені теми інформаційної безпеки для обговорення під час проведення співбесід; PS-04a. при звільненні працівника доступ до системи вимикається протягом часового періоду; PS-04b. припиняють дію або анулюють будь-які автентифікатори та облікові дані після припинення трудових відносин з окремими особами; PS-04c. проводяться при звільненні окремих працівників співбесіди, які включають обговорення питань інформаційної безпеки; PS-04d. отримується після звільнення особи все майно, пов'язане з безпекою організаційної системи; PS-04e. зберігається доступ до організаційної інформації та систем, які раніше перебували під контролем особи, що звільняється, після припинення нею трудових відносин Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
136	Переведення персоналу (PS-5)		PS-5	Вимоги до безпеки персоналу визначаються політиками управління кадрами та процедурами допуску до інформації в системі ЄСІКС. Параметр: Визначені дії, які мають бути ініційовані після переведення або перепризначення Тип: list Значення: login, logout, failed_attempt Параметр: Визначено період часу, протягом якого мають бути здійснені дії з переведення або перепризначення після переведення або перепризначення Тип: list Значення: login, logout, failed_attempt Параметр: Визначено персонал або ролі, про які необхідно повідомляти, коли осіб призначають на інші посади або переводять на інші посади в організації Тип: list Значення: admin, security_officer Параметр: Визначено період часу, протягом якого необхідно повідомляти визначений організацією персонал або ролі, коли осіб перепризначають або переводять на інші посади в межах організації; PS-05a. переглядаються та підтверджуються поточні потреби в логічних та фізичних дозволах на доступ до систем та об'єктів при перепризначенні або переведенні осіб на інші посади в організації; PS-05b. були ініційовані дії з переведення або перепризначення протягом періоду часу після формальної дії з переведення; PS-05c. змінюється авторизація доступу за необхідності, щоб відповідати будь-яким змінам в оперативних

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
14. ОЦІНКА РИЗИКІВ (RA)				
137	ПОЛІТИКА ТА ПРОЦЕДУРИ ОЦІНЮВАННЯ РИЗИКУ (RA-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]: 1. 2. Політику оцінювання ризику, яка: (а) містить мету, сферу застосування, ролі, обов’язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і керівним принципам. Процедури, що сприяють здійсненню політики оцінювання ризику та пов’язаних з ними заходів оцінювання ризику. б. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами оцінювання ризику. с. Переглядати й оновлювати: 1. Поточну політику оцінювання організацією частотою]. ризику [Призначення: з визначеною 2. Поточні процедури оцінювання ризику [Призначення: з визначеною організацією частотою].	RA-1	Оцінка ризиків здійснюється з урахуванням вимог OWASP Top 10 та чинного законодавства України з кібербезпеки. Параметр: Визначено персонал або ролі, на які поширюється політика оцінювання ризику Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури, що сприяють здійсненню політики оцінювання ризику Тип: list Значення: admin, security_officer Параметр: Визначена посадова особа, відповідальна за управління політикою та процедурами оцінювання ризику Тип: list Значення: admin, security_officer Параметр: Визначена періодичність перегляду та оновлення поточної політики оцінювання ризику Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які вимагають перегляду та оновлення поточної політики оцінювання ризику Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено періодичність перегляду поточних процедур оцінювання ризику Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
138	ОЦІНЮВАННЯ РИЗИКУ (RA-3)		RA-3	Всі ідентифіковані вразливості або загрози фіксуються в реєстрі 'itsm', де їм присвоюється рівень критичності. На базі цього рівня розраховується пріоритет та призначаються відповідальні особи. Параметр: risk_assessment Тип: boolean Значення: true
139	ОЦІНЮВАННЯ ПОСТАЧАВАННЯ (RA-3(1))		RA-3(1)	Оцінка ризиків здійснюється з урахуванням вимог OWASP Top 10 та чинного законодавства України з кібербезпеки.
140	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5)	Використовувати заходи ПДТР за [Призначення: визначені організацією місця] [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: за визначеними організацією подіями або показниками]].	RA-5	Система передбачає можливість інтеграції зовнішніх сканерів вразливостей, звіти яких автоматично перетворюються на тикети усунення ризиків в системі 'itsm'. Параметр: vulnerability_scanning Тип: boolean Значення: true
141	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ - ОНОВЛЕННЯ ЗА ЧАСТОТОЮ, ПЕРЕД НОВИМ СКАНУВАННЯМ АБО ПРИ ІДЕНТИФІКАЦІЇ (RA-5(2))		RA-5(2)	Оцінка ризиків здійснюється з урахуванням вимог OWASP Top 10 та чинного законодавства України з кібербезпеки. Параметр: Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику Тип: integer Значення: 30
142	РЕАГУВАННЯ НА РИЗИК (RA-7)	Реагувати на результати оцінювання, моніторингу й аудиту безпеки та приватності.	RA-7	Оцінка ризиків здійснюється з урахуванням вимог OWASP Top 10 та чинного законодавства України з кібербезпеки.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
15. ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA)				
143	ПОЛІТИКИ ТА ПРОЦЕДУРИ ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]: 1. 2. б. [Вибір (один або декілька): рівень організації; рівень місії/бізнес-процесу; рівень системи] політики придбання систем і послуг, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і рекомендаціям. Процедури, що полегшують впровадження політики та заходів придбання систем і послуг. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами придбання системи та послуг. с. Переглядати й оновлювати поточні політику та процедури придбання систем та послуг: 1. Поточну політику придбання системи та послуг [Призначення: з визначеною організацією частотою]. 2. Поточні процедури придбання системи та послуг [Призначення: з визначеною організацією частотою] та наступні [Призначення: події, визначені організацією].	SA-1	Інтеграція нових підсистем (SA) вимагає використання open-source компонентів та безкоштовного ПЗ, сумісного з мікросервісною архітектурою та стандартами ЄСІКС. Параметр: Визначено персонал або ролі, на які поширюватиметься політика придбання систем і послуг Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури придбання систем і послуг Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами придбання систем і послуг Тип: list Значення: admin, security_officer Параметр: Визначено періодичність перегляду та оновлення поточної політики придбання систем і послуг Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Є події, які вимагають перегляду та оновлення поточної політики придбання систем і послуг Тип: list Значення: default _ deny _ rule, abac _ rule _1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури придбання систем і послуг Тип: integer Значення: 30
144	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ІНЖИНІРИНГУ (SA-8)	Застосовувати [Призначення: визначені організацією принципи інжинірингу безпеки та конфіденційності системи] в специфікації, проектуванні, розробці, впровадженні та зміні системи й компонентів системи.	SA-8	Інтеграція нових підсистем (SA) вимагає використання open-source компонентів та безкоштовного ПЗ, сумісного з мікросервісною архітектурою та стандартами ЄСІКС.

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
145	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)	а. Вимагати, щоб постачальники зовнішніх послуг для системи відповідали вимогам безпеки та приватності в організації та застосовували такі заходи захисту [Призначення: встановлені організацією заходи безпеки та приватності]. б. Визначити та задокументувати нагляд організаціїповноваження та обов'язки користувачів щодо зовнішніх послуг для системи. с. Використовувати наступні процеси, методи та техніки для постійного моніторингу дотримання контролю зовнішніми постачальниками послуг: [Призначення: визначені організацією процеси, методи та техніки].	SA-9	Інтеграція нових підсистем (SA) вимагає використання open-source компонентів та безкоштовного ПЗ, сумісного з мікросервісною архітектурою та стандартами ЄСІКС. Параметр: Визначені засоби контролю, які будуть застосовуватися зовнішніми постачальниками системних послуг Тип: string Значення: автоматизований засіб моніторингу Параметр: Визначені процеси, методи та техніки, що застосовуються для моніторингу дотримання вимог контролю зовнішніми постачальниками послуг; SA-09a.[01] дотримуються постачальники зовнішніх системних послуг вимог організаційної безпеки; SA-09a.[02] дотримуються постачальники зовнішніх системних послуг вимог приватності організації; SA-09a.[03] використовують постачальники зовнішніх системних послуг елементи керування; SA-09b.[01] визначено та задокументовано організаційний нагляд за зовнішніми системними послугами; SA-09b.[02] визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних сервісів; SA-09c. визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних послуг Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
146	КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)	а. Замінювати компоненти системи, якщо підтримка компонентів більше не доступна розробнику, постачальнику або виробнику. б. Надавати такі варіанти альтернативних джерел для подальшої підтримки непідтримуваних компонентів [Вибір (один або більше): внутрішня підтримка; [Призначення: підтримка, визначена організацією від зовнішніх постачальників]].	SA-22	Інтеграція нових підсистем (SA) вимагає використання open-source компонентів та безкоштовного ПЗ, сумісного з мікросервісною архітектурою та стандартами ЄСІКС.
16. ЗАХИСТ СИСТЕМ ТА КОМУНІКАЦІЙ (SC)				
147	ПОЛІТИКА ТА ПРОЦЕДУРИ ЗАХИСТУ СИСТЕМИ ТА КОМУНІКАЦІЙ (SC-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]: 1. 2. Політику захисту системи та комунікацій, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (б) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам. Процедури для сприяння впровадженню політики в області захисту систем і комунікацій, а також пов'язаних з ними систем і засобів захисту зв'язку. б. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами захисту системи та комунікацій. с. Переглядати та оновлювати: 1. поточну політику захисту системи та комунікацій [Призначення: визначена організацією частота]; 2. поточні процедури захисту системи та комунікацій [Призначення: визначена організацією частота].	SC-1	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC. Параметр: Визначено персонал або ролі, до яких має бути доведена політика захисту системи та комунікацій Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури захисту системи та комунікацій Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами захисту системи та комунікацій Тип: list Значення: admin, security_officer Параметр: Визначена періодичність перегляду та оновлення поточної політики захисту системи та комунікацій Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Є події, які вимагають перегляду та оновлення поточної політики захисту системи та комунікацій Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначена періодичність перегляду та оновлення поточних процедур захисту системи та засобів зв'язку Тип: string Значення: щорічно
148	ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)	Запобігати несанкціонованій та ненавмисній передачі інформації через спільні системні ресурси.	SC-4	Erlang VM не використовує спільну пам'ять (shared memory) між процесами сесій N2O. Пам'ять звільняється автоматично (Garbage Collection) після обробки запиту, запобігаючи витоку залишкової інформації між різними користувачами. Параметр: shared_resource_protection Тип: boolean Значення: true
149	ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)	а. Контролювати та управляти зв'язком на зовнішньому периметрі системи та на ключових внутрішніх периметрах всередині системи. б. Реалізувати підмережі для загальнодоступних компонентів системи, які є [Вибір: фізично; логічно] відділені від внутрішніх мереж організації. с. Підключатися до зовнішніх мереж або систем тільки через керовані інтерфейси, що складаються з пристроїв захисту периметру, і розташованих відповідно до архітектури безпеки та приватності організації.	SC-7	Всі зовнішні підключення приймаються виключно через єдиний порт (керований інтерфейс), що обробляється веб-сервером (Cowboy). Доступ до внутрішніх API і вузлів кластера блокується правилами мережевого екранування за замовчуванням (Default Deny). Параметр: boundary_protection Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
150	ЗАХИСТ ПЕРИМЕТРА - ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))		SC-7(5)	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC.
151	КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)	Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] інформації, що передається.	SC-8	Передача інформації між клієнтом і сервером здійснюється виключно через зашифровані канали (WSS/TLS), що унеможлиблює перехоплення (Man-in-the-Middle) або несанкціоновану модифікацію даних на льоту. Параметр: transmission_confidentiality Тип: boolean Значення: true
152	КОНФІДЕНЦІЙНІСТЬ ТА КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-8(1))		SC-8(1)	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC.
153	КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ - ПОПЕРЕДНЯ І ПОСТОВРІВКА (SC-8(2))		SC-8(2)	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC.
154	ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)	Завершити з'єднання з мережею, яке пов'язане із сеансом зв'язку в кінці сеансу або після [Призначення: визначений організацією період часу] бездіяльності.	SC-10	Протокол N2O автоматично розриває мережеве з'єднання після завершення комунікаційного сеансу або перевищення часу очікування (Inactivity Timeout), звільняючи ресурси та сесію. Параметр: network_disconnect_timeout Тип: integer Значення: 3600

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
155	ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)	Встановити та управляти криптографічними ключами для криптографічних засобів, які використовуються в системі відповідно до [Призначення: визначені організацією вимоги до генерації, поширення, зберігання, доступу та знищення ключів].	SC-12	Керування ключами та сертифікатами для встановлення захищених з'єднань делегується бібліотеці 'synrc/ca' та інтегрованим механізмам TLS OC, що відповідають чинним криптографічним стандартам. Параметр: cryptographic_key_management Тип: boolean Значення: true
156	КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)	a. Визначити [Призначення: використання криптографічних засобів, визначених організацією]; b. Впровадити [Завдання: визначені організацією види криптографії для кожного визначеного криптографічного використання].	SC-13	Система підтримує використання схвалених криптографічних алгоритмів (AES-GCM, SHA-256/512, ДСТУ 4145-2002 через відповідні модулі), які забезпечують необхідний рівень стійкості. Параметр: cryptographic_protection Тип: boolean Значення: true
157	СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)	a. Заборонити віддалену активацію спільних обчислювальних пристроїв (хмар) та застосунків з такими виключеннями: [Призначення: визначені організацією виключення, у яких дозволена віддалена активація]. b. Надати явну вказівку щодо використання користувачами фізично присутніми пристроями.	SC-15	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC.
158	СЕРТИФІКАТИ ІНФРАСТРУКТУРИ ВІДКРИТИХ КЛЮЧІВ (SC-17)	a. Випускати сертифікати відкритого ключа відповідно до [Призначення: визначеної організацією політики сертифікації]; b. Отримувати сертифікати відкритого ключа від затвердженого постачальника послуг.	SC-17	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC.
159	МОБІЛЬНИЙ КОД (SC-18)	a. Визначити прийнятні та неприйнятні мобільні коди та технології мобільних кодів. b. Проводити авторизацію, відстежувати та контролювати використання мобільного коду всередині системи.	SC-18	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
160	АВТЕНТИФІКАЦІЯ СЕСІЙ (SC-23)	Забезпечити автентифікацію сеансів зв'язку.	SC-23	Автентичність WebSocket-сесій N2O захищається токенами з криптографічним підписом (HMAC). Це гарантує, що повідомлення в рамках сесії не можуть бути підроблені або інжектвані сторонньою особою. Параметр: session_authenticity Тип: boolean Значення: true
161	ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)	Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] [Призначення: визначена організацією інформація] в стані спокою.	SC-28	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC.
162	ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ КРИПТОГРАФІЧНИЙ ЗАХИСТ		SC-28(1)	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC. Параметр: Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях Тип: string Значення: AES-256-GCM Параметр: Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях Тип: string Значення: AES-256-GCM

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
163	ЕКРАНОВАНІ КАМЕРИ (SC-44)	Впровадити екрановані камери в [Призначення: визначену організацією систему, компонент системи або місце розташування].	SC-44	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC.
164	ПРИМУСОВЕ АПАРАТНЕ ЗАБЕЗПЕЧЕННЯ ВИКОНАННЯ (SC-49)	Впровадити механізми апаратного поділу та застосування політики між [Призначення: домени безпеки, визначені організацією].	SC-49	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC. Параметр: Впроваджено механізми апаратного розділення та застосування політик між доменами безпеки Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Визначені домени безпеки, які потребують апаратного розділення та механізмів забезпечення дотримання політики Тип: list Значення: default _deny_rule, abac _rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
165	АПАРАТНИЙ ЗАХИСТ (SC-51)	а. Перевіряти правильність роботи [Призначення: визначені організацією функції безпеки та приватності]. б. Виконувати перевірку [Вибір (один або кілька): [Призначення: визначені організацією системні перехідні стани]; за командою користувача з відповідними повноваженнями; [Призначення: визначена організацією частота]]. с. Повідомляти [Призначення: визначені організацією персонал або посадові особи] про невдалі перевірки безпеки та приватності. д. [Вибір (один або кілька): Вимкнути систему; Перезапустити систему; [Призначення: визначені організацією альтернативні дії]], коли виявляються аномалії.	SC-51	Комунікації захищені TLS версії не нижче 1.3 на порту 443. Заборонено відкривати інші порти назовні. Взаємодія сервісів використовує брокери повідомлень та REST/RPC. Параметр: Визначені уповноважені особи, які повинні виконувати процедури вимкнення та повторного увімкнення апаратного захисту від запису; SC-51a. використовується апаратний захист від запису для компонентів мікропрограми системи; SC-51b.[01] впроваджено спеціальні процедури для уповноважених осіб для ручного вимкнення апаратного захисту від запису для модифікацій мікропрограми; SC-51b.[02] реалізовано спеціальні процедури для уповноважених осіб для повторного увімкнення захисту від запису перед поверненням до робочого режиму Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
17. ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ (SI)				
166	ПОЛІТИКА І ПРОЦЕДУРИ ЦІЛІСНОСТІ ІНФОРМАЦІЇ (SI-1)		SI-1	Цілісність даних забезпечується захистом від SQL та XSS ін'єкцій, екрануванням спецсимволів, валідацією JSON Schema та імутабельністю історичних даних (HL7, BPMN). Параметр: Визначено персонал або ролі, до яких має бути доведена політика цілісності системи та інформації Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури цілісності системи та інформації Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, відповідальну за управління системою та політикою і процедурами цілісності інформації Тип: list Значення: admin, security_officer Параметр: Визначено періодичність перегляду та оновлення поточної політики цілісності системи та інформації Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Є події, які вимагають перегляду та оновлення поточної політики цілісності системи та інформації Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні цілісності системи та інформації Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
167	ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)		SI-2	Цілісність даних забезпечується захистом від SQL та XSS ін'єкцій, екрануванням спецсимволів, валідацією JSON Schema та імітабельністю історичних даних (HL7, BPMN). Параметр: Визначено період часу, протягом якого необхідно встановити оновлення програмного забезпечення, пов'язані з безпекою, після виходу оновлень; SI-02a.[01] виявлено недоліки системи; SI-02a.[02] повідомляється про недоліки системи; SI-02a.[03] виправлені недоліки системи; SI-02b.[01] перевіряються оновлення програмного забезпечення, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[02] перевіряються оновлення програмного забезпечення, пов'язані з виправленням дефектів, на наявність потенційних побічних ефектів перед встановленням; SI-02b.[03] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[04] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на наявність потенційних побічних ефектів перед встановленням; SI-02c.[01] встановлено оновлення програмного забезпечення, що стосуються безпеки, протягом часовий проміжок з моменту випуску оновлень; SI-02c.[02] встановлено оновлення мікропрограми, що стосуються безпеки,

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
168	ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)		SI-3	Цілісність даних забезпечується захистом від SQL та XSS ін'єкцій, екрануванням спецсимволів, валідацією JSON Schema та імутабельністю історичних даних (HL7, BPMN). Параметр: Визначено частоту, з якою механізми шкідливого коду виконують сканування Тип: integer Значення: 30 Параметр: Визначено дії, яких слід вжити у відповідь на виявлення шкідливого коду (якщо вибрано) Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
169	МОНІТОРИНГ СИСТЕМИ (SI-4)		SI-4	Цілісність даних забезпечується захистом від SQL та XSS ін'єкцій, екрануванням спецсимволів, валідацією JSON Schema та імітабельністю історичних даних (HL7, BPMN). Параметр: Визначені методи та способи, що використовуються для виявлення несанкціонованого використання системи Тип: list Значення: admin, security_officer Параметр: Визначена інформація про моніторинг системи, яка повинна надаватися персоналу або ролям Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, яким має надаватися інформація про моніторинг системи Тип: list Значення: admin, security_officer Параметр: Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {за потребою; частота} Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
170	МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(4))		SI-4(4)	Цілісність даних забезпечується захистом від SQL та XSS ін'єкцій, екрануванням спецсимволів, валідацією JSON Schema та імітабельністю історичних даних (HL7, BPMN). Параметр: Визначені критерії незвичної або несанкціонованої діяльності або умови для вхідного трафіку зв'язку Тип: list Значення: Параметр: Визначені критерії незвичайної або несанкціонованої діяльності або умови для вихідного трафіку зв'язку Тип: list Значення: Параметр: Здійснюється моніторинг вхідного трафіку частота на предмет незвичних або несанкціонованих дій або умов Тип: string Значення: щорічно Параметр: Контролюється вихідний трафік зв'язку частота на предмет незвичних або несанкціонованих дій або умов. вихідного виявлення Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
171	ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)		SI-5	Цілісність даних забезпечується захистом від SQL та XSS ін'єкцій, екрануванням спецсимволів, валідацією JSON Schema та імітабельністю історичних даних (HL7, BPMN). Параметр: Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {персонал або ролі; елементи; зовнішні організації} Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, до яких мають бути доведені попередження, поради та директиви з безпеки (якщо визначено) Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
172	ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ (SI-7)	а. Впровадити механізми захисту від спаму в точках входу та виходу системи, щоб виявляти та протидіяти небажаним повідомленням. б. Оновлювати механізми захисту від спаму, коли доступні нові механізми відповідно до організаційної політики та процедур управління конфігурацією.	SI-7	Цілісність даних забезпечується захистом від SQL та XSS ін'єкцій, екрануванням спецсимволів, валідацією JSON Schema та імутабельністю історичних даних (HL7, BPMN). Параметр: Визначені дії, яких слід вжити при виявленні несанкціонованих змін у програмному забезпеченні Тип: list Значення: login, logout, failed_attempt Параметр: Визначені дії, яких слід вжити несанкціонованих змін у прошивці; при виявленні SI-07_ODP[06] визначені дії, яких слід вжити несанкціонованих змін до інформації; при виявленні SI-07a.[01] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін у програмному забезпеченні; SI-07a.[02] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін у мікропрограмі; SI-07a.[03] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін до інформації; SI-07b.[01] виконуються дії при виявленні несанкціонованих змін у програмному забезпеченні; SI-07b.[02] виконуються дії несанкціонованих змін у прошивці; при виявленні SI-07b.[03] виконуються дії несанкціонованих змін в інформації. Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
173	УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)	Управляти та зберігати інформацію всередині системи та виводити інформацію із системи відповідно до чинного законодавства, виконавчих наказів, директив, правил, політик, стандартів, керівних принципів та експлуатаційних вимог.	SI-12	Цілісність даних забезпечується захистом від SQL та XSS ін'єкцій, екрануванням спецсимволів, валідацією JSON Schema та імутабельністю історичних даних (HL7, BPMN). Параметр: Здійснюється управління інформацією в системі відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Зберігається інформація в системі відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Управління інформацією, що виводиться з системи, здійснюється відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та операційних вимог Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Зберігається інформація, що виводиться з системи, відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Тип: list Значення: default _deny_rule, abac _rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
18. УПРАВЛІННЯ РИЗИКАМИ В ЛАНЦЮГУ ПОСТАЧАННЯ (SR)				
174	ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-1)	а. Розробіть, задокументуйте та поширте [Призначення: персонал або ролі, визначені організацією]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика управління ризиками ланцюга постачання, яка: а) Розглядає мету, сферу діяльності, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та відповідність; б) Відповідає чинним законам, виконавчим наказам, директивам, положенням, політикам, стандартам і вказівкам; 2. Процедури для сприяння впровадженню політики управління ризиками ланцюга постачання та відповідних засобів контролю управління ризиками ланцюга постачання; б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур управління ризиками ланцюга постачання; с. Перегляньте та оновіть поточне управління ризиками ланцюга постачання: 1. Політика [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].	SR-1	Управління ризиками ланцюга постачання базується на перевірці бібліотек через exploit-db та обов'язковому оновленні вразливостей. Параметр: Визначено персонал або ролі, на які поширюється політика управління ризиками ланцюга постачання Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури управління ризиками ланцюга постачання Тип: list Значення: admin, security_officer Параметр: Визначена посадова особа, відповідальна за розробку, документування та розповсюдження політики та процедур управління ризиками ланцюга постачання Тип: list Значення: admin, security_officer Параметр: Визначена періодичність перегляду та оновлення поточної політики управління ризиками ланцюга постачання Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
				Параметр: Є події, які вимагають перегляду та оновлення поточної політики управління ризиками ланцюга постачання Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначена періодичність перегляду та оновлення поточної процедури управління ризиками ланцюга постачання Тип: string Значення: щорічно
175	ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)	а. Розробіть план управління ризиками ланцюга постачання, пов'язаними з дослідженнями та розробкою, проектуванням, виробництвом, придбанням, доставкою, інтеграцією, експлуатацією та обслуговуванням, а також утилізацією таких систем, компонентів системи або послуг для системи: [Призначення: системи, визначені організацією, системні компоненти або системні служби]; б. Перегляньте та оновіть план управління ризиками ланцюга постачання [Призначення: частота, визначена організацією] або за потреби для усунення загроз; с. Захистіть план управління ризиками ланцюга постачання від несанкціонованого розголошення та модифікації.	SR-2	План управління базується на принципі відмови від стороннього коду. Замість інтеграції сотень неперевіраних бібліотек, команда розробляє всі необхідні компоненти (веб-сервер N2O, KVS, CA) самостійно в єдиному монорепозіторії. Параметр: zero_dependency_policy Тип: boolean Значення: true
176	КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)	а. Встановлення процесу або процесів для виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання [Призначення: визначена організацією система або компонент системи] у координації з [Завдання: персонал ланцюга постачання, визначений організацією]; б. Використовуйте такі заходи захисту, щоб захистити систему, компонент системи або системну службу від ризиків ланцюга постачання та обмежити шкоду чи наслідки від подій, пов'язаних із ланцюгом постачання: [Призначення: заходи захисту ланцюга постачання, визначені організацією]; с. Задokumentуйте обрані та впроваджені процеси та заходи захисту ланцюгом постачання у [Вибір: плани безпеки та приватності; план управління ризиками ланцюга постачання; [Призначення: документ, визначений організацією]].	SR-3	Заборонено використання автоматичних менеджерів пакетів для завантаження коду під час збірки. Весь вихідний код системи та модулів міститься безпосередньо в репозиторії проекту, що гарантує 100% контроль над кожним рядком коду, який компілюється. Параметр: strict_code_vendoring Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
177	СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)	Використовуйте наступні стратегії придбання, контрактні інструменти та методи закупівель, щоб захистити від ризиків ланцюга постачання, визначити та пом'якшити їх: [Призначення: визначені організацією стратегії придбання, контрактні інструменти та методи закупівель].	SR-5	Управління ризиками ланцюга постачання базується на перевірці бібліотек через exploit-db та обов'язковому оновленні вразливостей.
178	ОЦІНКА ПОСТАЧАЛЬНИКІВ (SR-6)	Оцініть і перегляньте ризики ланцюга постачання, пов'язані з постачальниками або підрядниками, системою, системним компонентом або системною послугою, яку вони надають [Призначення: частота, визначена організацією].	SR-6	Єдиним зовнішнім «постачальником» є розробник платформи Erlang/OTP (компанія Ericsson та спільнота). Оновлення версій OTP проходять жорстку перевірку перед їх застосуванням на продуктивних серверах. Параметр: erlang_otp_supplier_review Тип: boolean Значення: true